INSA
INSTITUT NATIONAL
DES SCIENCES
APPLIQUÉES
LYON



Réseaux sans fil
Architecture et Sécurité

Walid Bechkit, INSA-Lyon, INRIA-CITI

citi lab

Inria
INVENTEURS DU MONDE NUMÉRIQUE

membre de
UNIVERSITÉ DE LYON

Aperçu sur le contenu de la formation

- **Introduction à la sécurité et aux réseaux sans fil**
  - Notions de base
  - Classifications et positionnement
- **Réseaux locaux sans fil: WiFi 802.11**
  - Architecture et sécurité
- **Network Access Control**
  - Principe, AAA, 801.1X, EAP, mise en place
- **Sécurité des technologies IoT**
  - Architecture et sécurité

Contributeurs

➢ Intervenant et contributeur principal

– Walid Bechkit INSA-Lyon / INIRIA

walid.bechkit@{inria , insa-lyon}.fr

➢ Autres contributeurs

– Matthieu Cunche, INSA-Lyon

– Francois Lesueur, INSA-Lyon

– Razvan Stanica, INSA-Lyon

– Yacine Challal, U.T.Compiègne

– Marine Minier, Université de lorraine

Objectifs de cette formation

- Comprendre les différentes architectures et protocoles de communication à travers l'étude de types différents et représentatifs de réseaux;
- Connaître et comprendre les solutions de sécurité proposées par les technologies sans fil (WiFi, Zigbee, LoraWAN, etc.);
- Prendre conscience des enjeux de sécurité induits par la multiplication des objets utilisant des technologies sans fil;
- Savoir analyser les vulnérabilités des différentes technologies et les attaques contre les protocoles sans fil;
- Savoir protéger les environnements de communication sans fil contre les différentes attaques.

Introduction & Rappels

Notions de base en sécurité

Services de sécurité

Vérifier la légitimité de demande d'accès

Rendre l'information inintelligible à d'autres personnes

Vérifier que l'information n'a pas été altérée

Authentification

Confidentialité

Intégrité





Alice





Bob

Autres services

- **Non répudiation**

  s'assurer qu'une action réalisée par un utilisateur authentifié ne peut pas être répudiée par ce dernier

- **Disponibilité** (Availability, CIA)
  - Un système (industriel) doit rester accessible et opérationnel
  - Le cas contraire entraine des pertes financières, retard de livraison, etc.

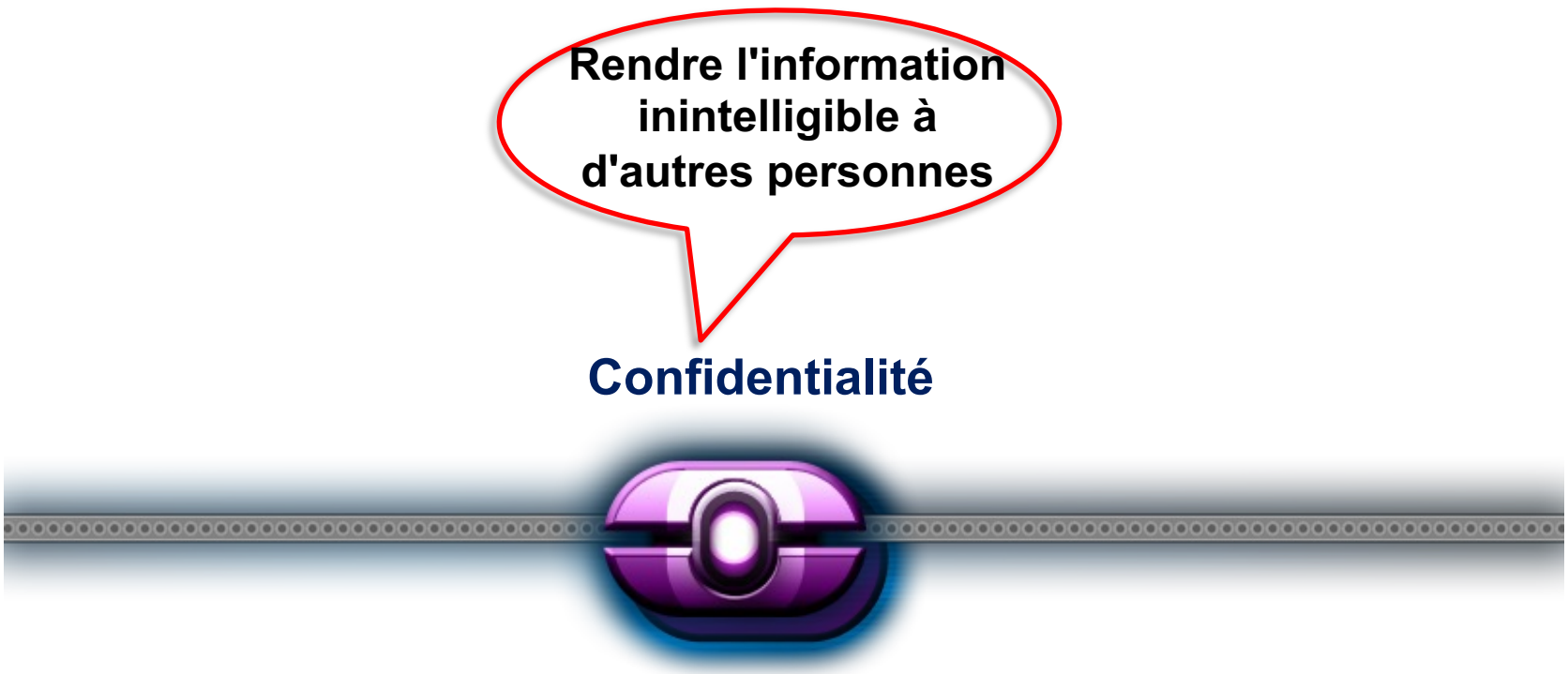
- **Traçabilité**
  - Capacité de retrouver l'historique des opérations, d'utilisation, de localisation, etc. d'une entité
  - Exigence réglementaire dans de certains domaines (nucléaire, transport,...)

- **Auditabilité**

  « fait référence à la traçabilité des opérations et des contrôles réalisés et de la documentation produite, les contrôles non documentés = non réalisés » *

* Guide méthodologique pour l'auditabilité des SI, ANSSI

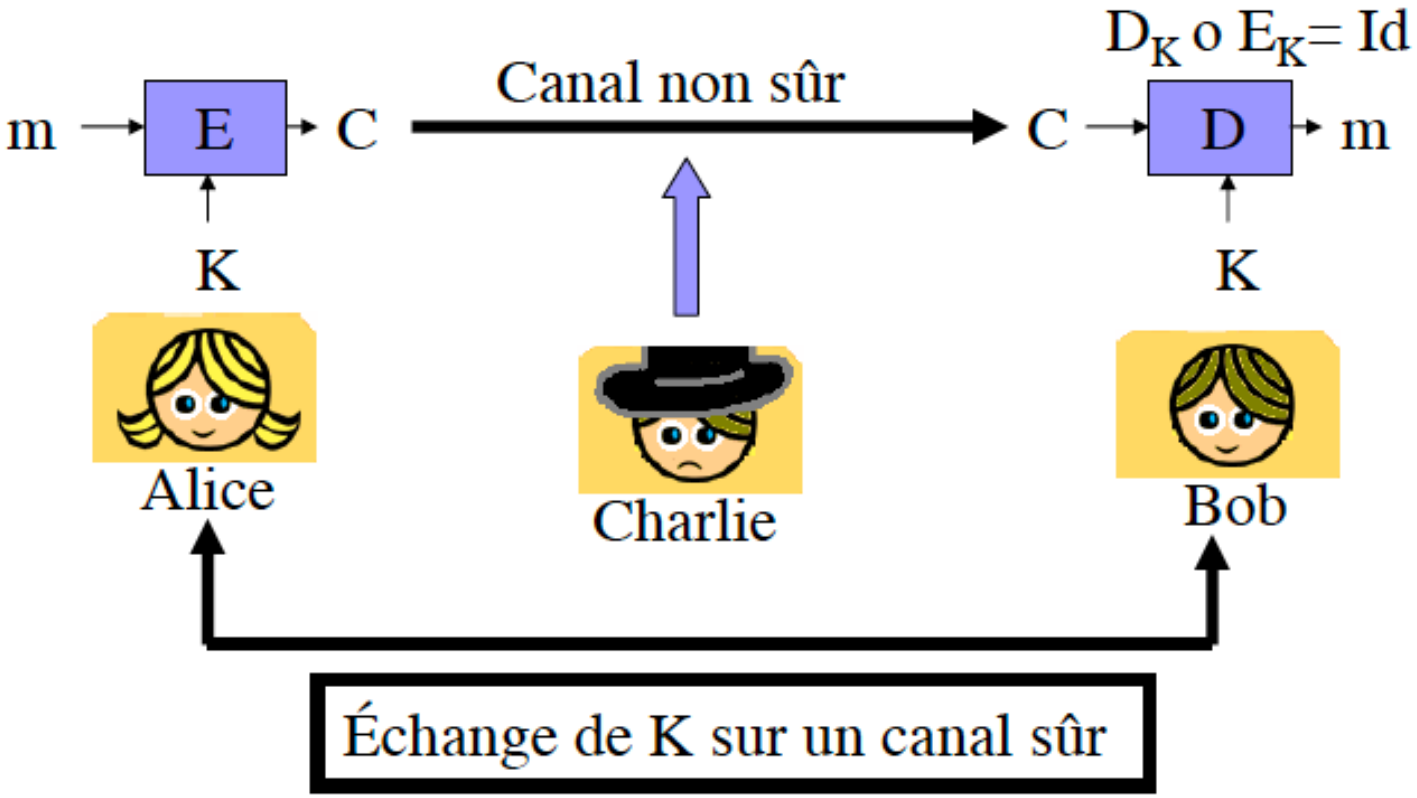
Services de sécurité



Définitions :

Chiffrement / Déchiffrement / Décryptage / cryptanalyse

Cryptographie symétrique à clé privée



Même clé pour chiffrer et déchiffrer

+ Algorithme très rapides
+ Faible taille des clés

- Distributions des clés
- Plus de clés à gérer : n(n-1)

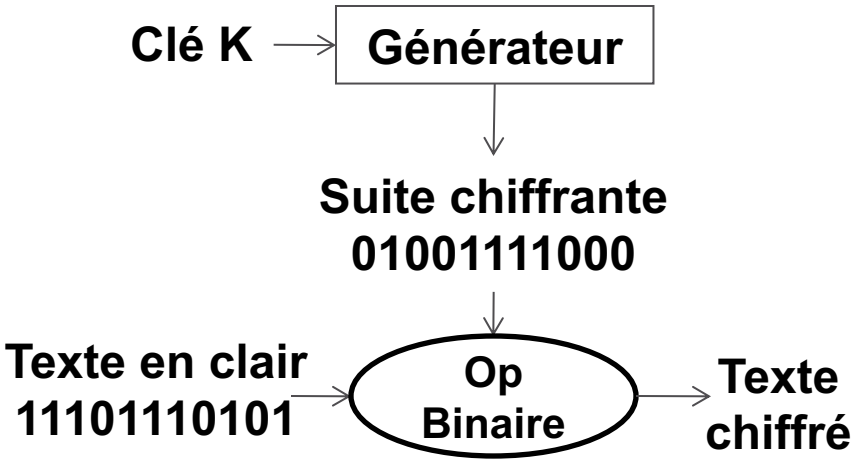
Chiffrement symétrique

Chiffrement symétrique par flot

+ Rapide

- Vulnérable à à la cryptanalyse

Exemples: **RC4**, **A5/1**, etc.

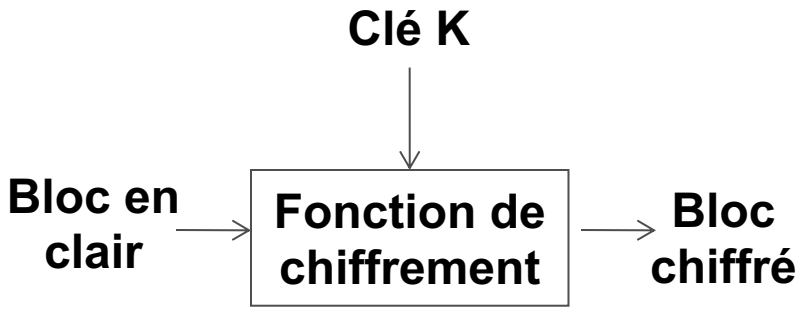


Chiffrement symétrique par bloc

+ Moins vulnérable à la cryptanalyse

- Lenteur

- Exemples: DES, **AES,** etc.



Exemple de chiffrement symétrique AES

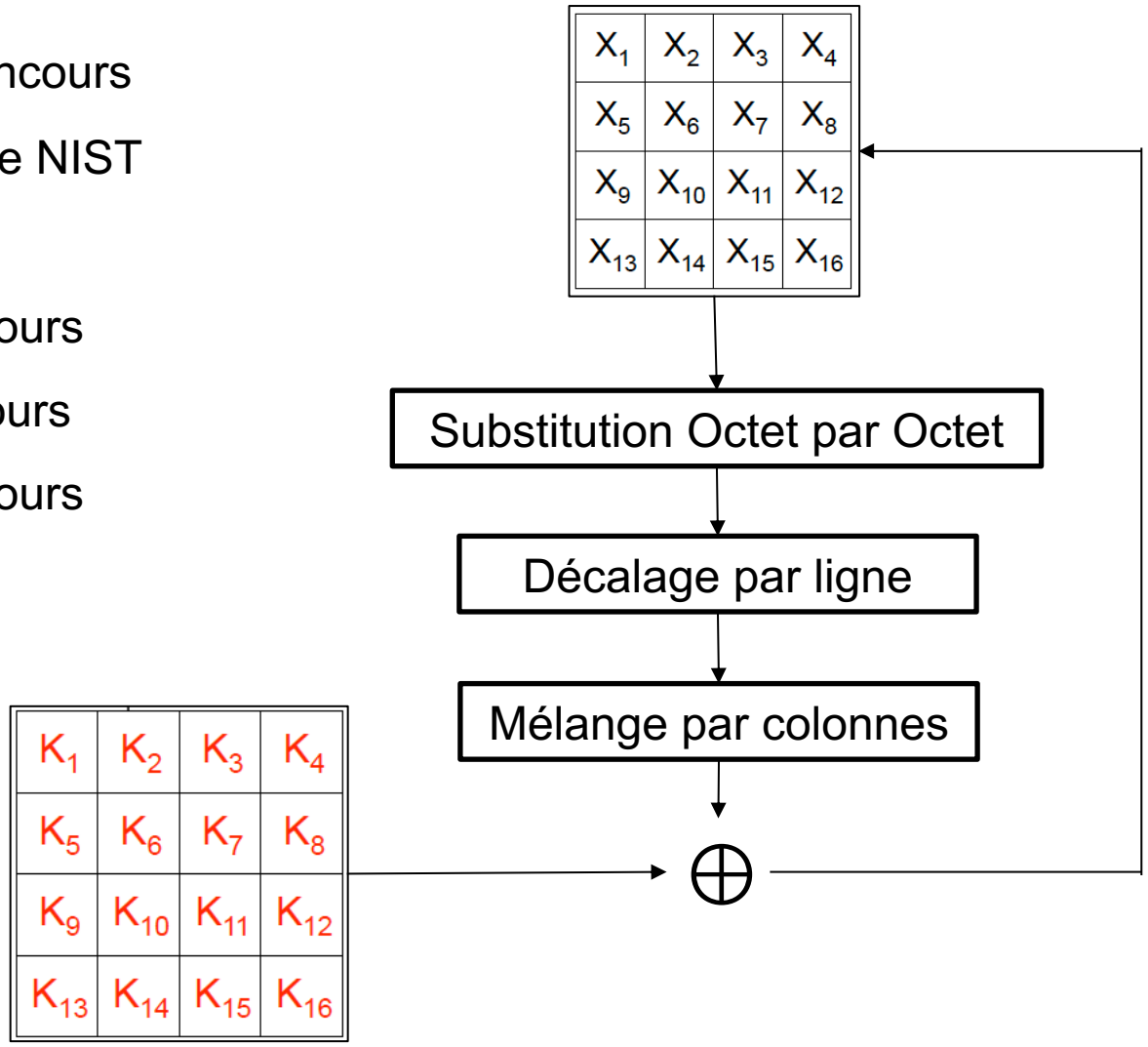
Remporte en 2000 le concours

AES, lancé en 1997 par le NIST

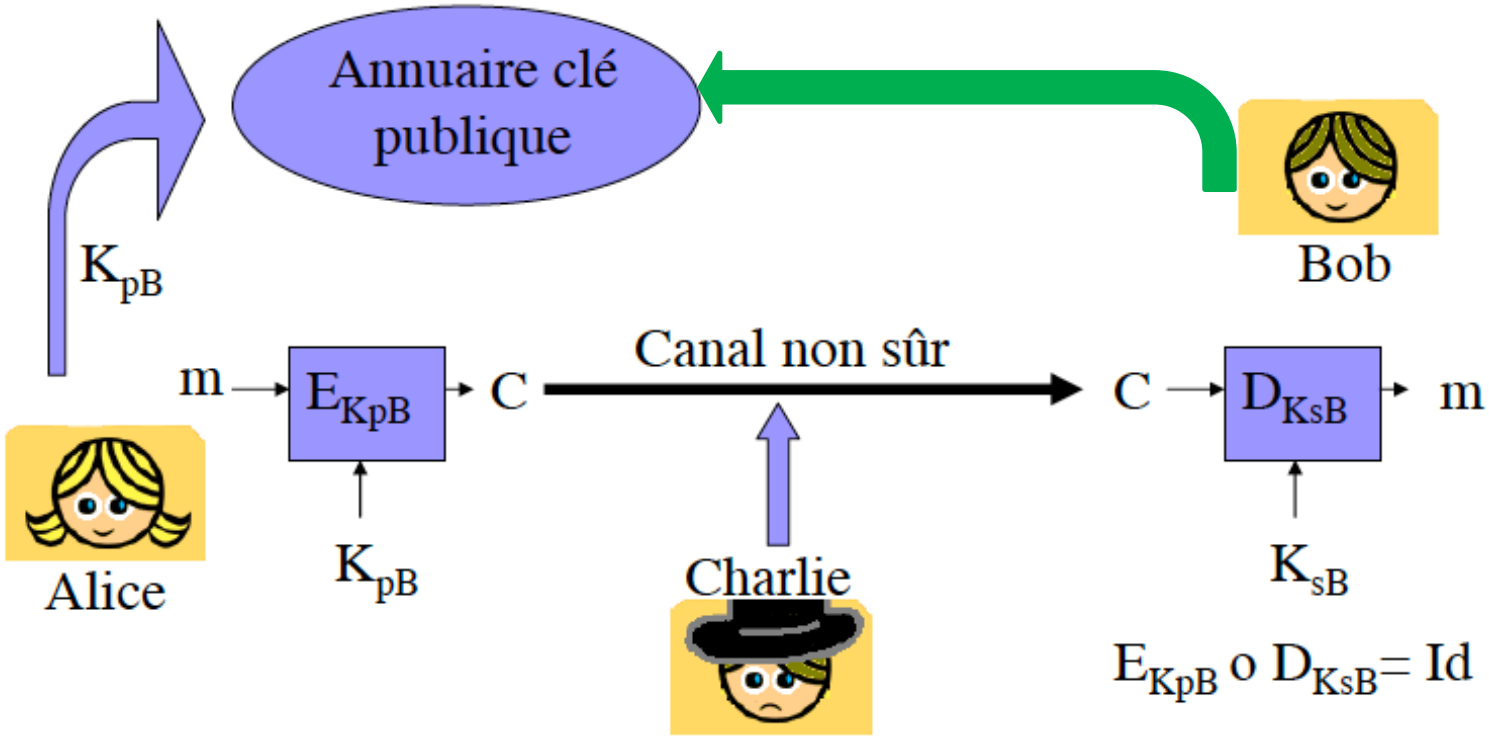
Clé 128 bits --> 10 tours

192 bits → 12 tours

256 bits --> 14 tours



Cryptographie asymétrique à clé publique

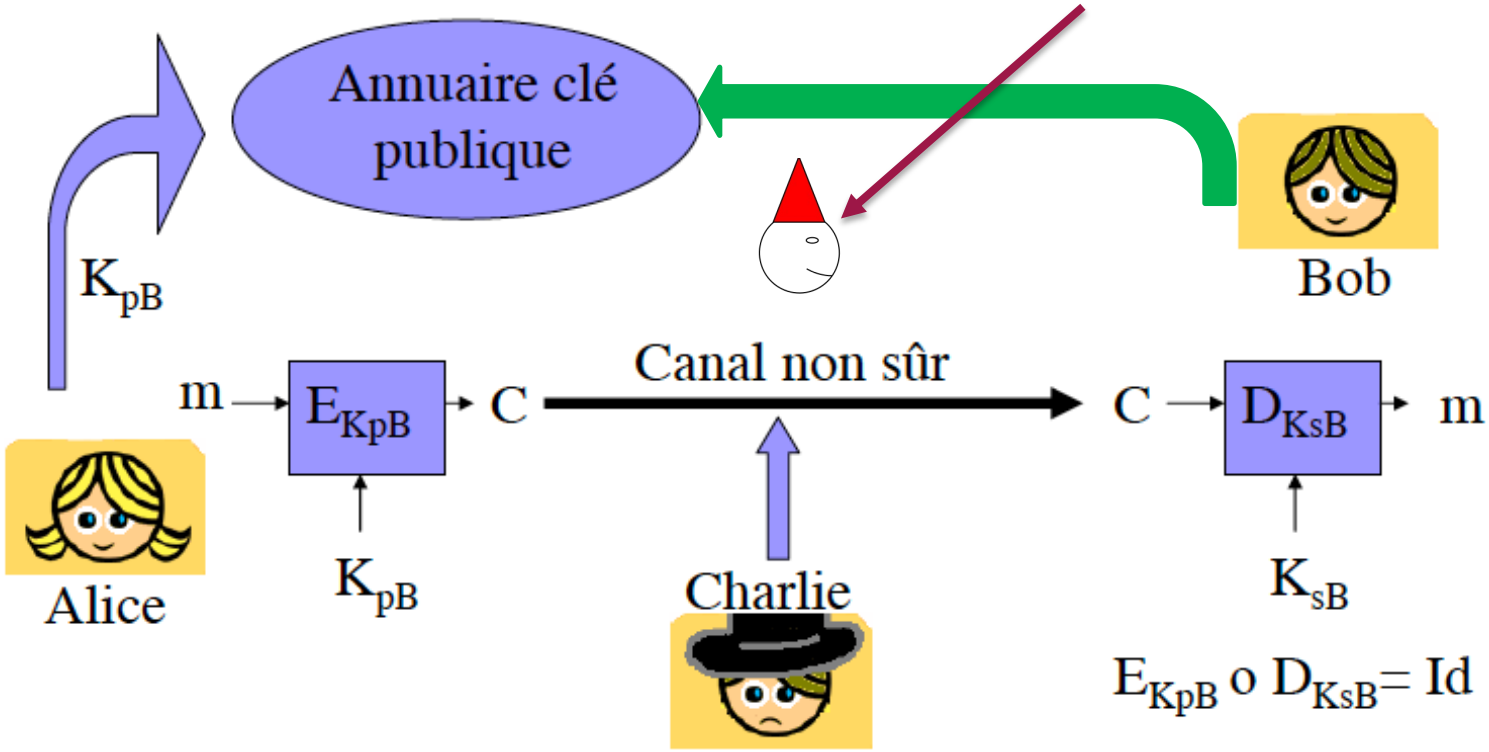


Une clé publique et une clé privée

+ Pas de prob de distribution de clés
+ Moins de clés à gérer 2.n

- Lenteur des algorithmes (~x1000)
- Taille des clés

Cryptographie asymétrique à clé publique



- Problème d'authenticité des clés publiques → PKI (CA, PGP, etc.)
- **Important: Clé publique pour chiffrer et clé privée pour déchiffrer**

Exemple de chiffrement asymétrique RSA

- **Génération de clés:** Bob génère ses clés
  - n=p.q avec p et q deux grands nombres premiers

    ex: p et q sur 1024 bits (309 chiffres décimaux chacun)

    Exemple simple pour comprendre : p=223 et q=233 n=51959

  - e premier avec phi(n) = (p-1)(q-1) et d tel que

    $e.d \equiv 1 \bmod (p-1)(q-1)$

    Sur l'exemple : e=5, d= 10301

  - Clé publique (n,e), clé privée d

    Sur l'exemple clé publique (5, 51959), clé privée 10301

Exemple de chiffrement asymétrique RSA

- **Chiffrement:** Alice veut envoyer un message m à Bob:
  - Alice calcule $C = M^{e} \bmod n$
  - Alice transmet C à Bob

    Sur l'exemple $C = M^{5} \bmod 51959$

- **Déchiffrement:** Bob déchiffre c en calculant :
  - $C^{d} = (M^{e})^{d} \bmod n$

    Sur l'exemple $M = C^{10301} \bmod 51959$

- Gestion des clés asymétriques → PKI (CA, DNSSEC, PGP, etc)

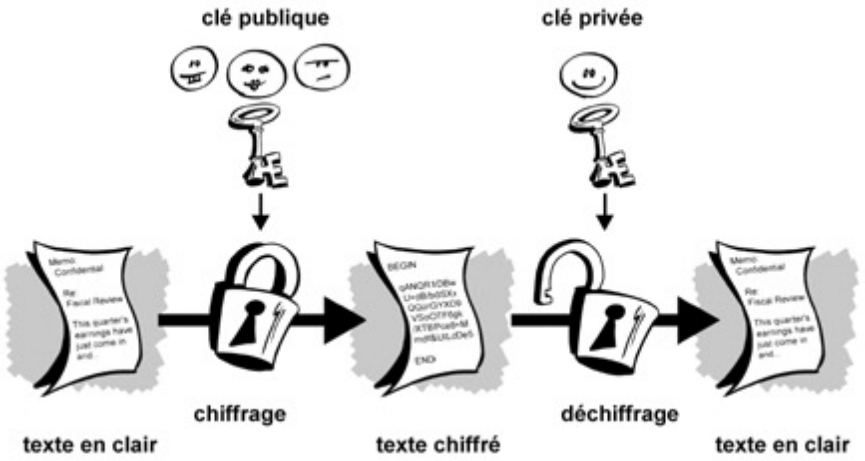
Chiffrement symétrique Vs asymétrique

Chiffrement asymétrique:

Une clé publique pour chiffrer et une clé privée pour déchiffrer (ex. RSA)

+ Pas de problème de distribution de clé

- Lenteur (~ x1000)



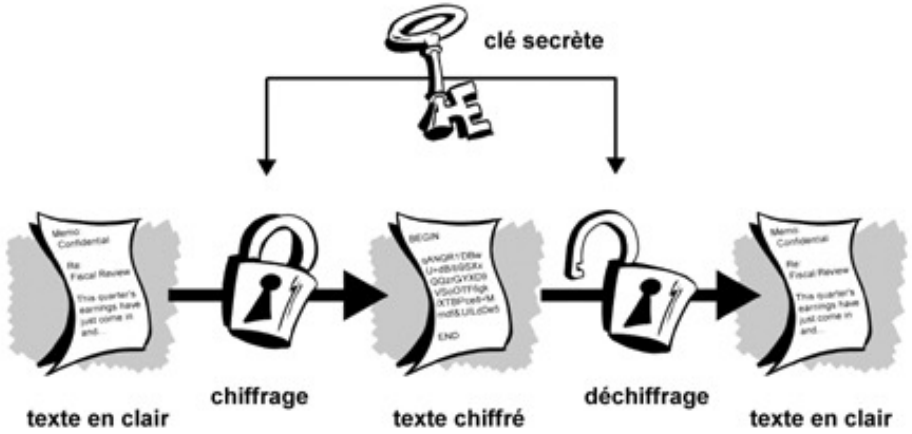
Chiffrement symétrique:

Même clé pour chiffrer et déchiffrer

Exemple : AES

+ Rapide

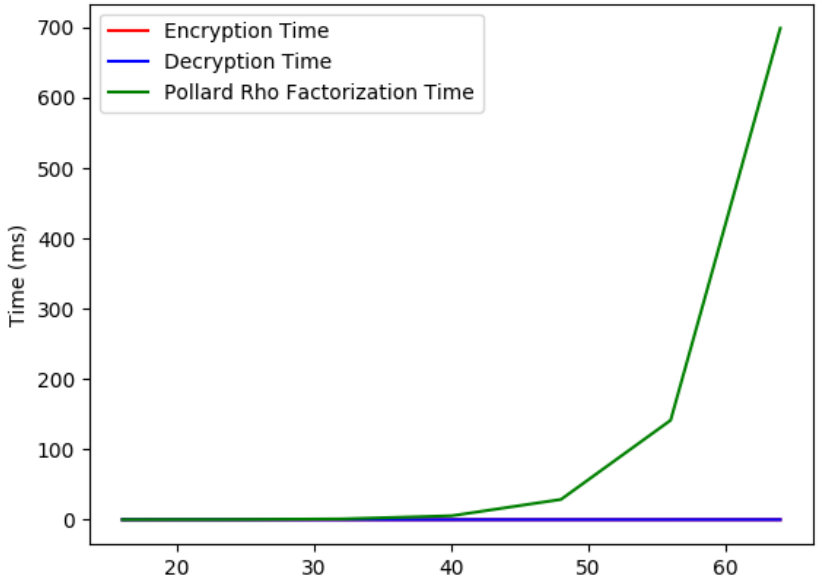
- Distributions des clés



Taille des clés

Taille des clés :

- La cryptanalyse pour les systèmes à clés secrètes repose sur la recherche exhaustive
- La cryptanalyse pour les systèmes à clés publiques repose sur différents problème complexe (factorisation de grand nombre pour RSA, logarithme discret pour les courbes elliptiques, etc.)



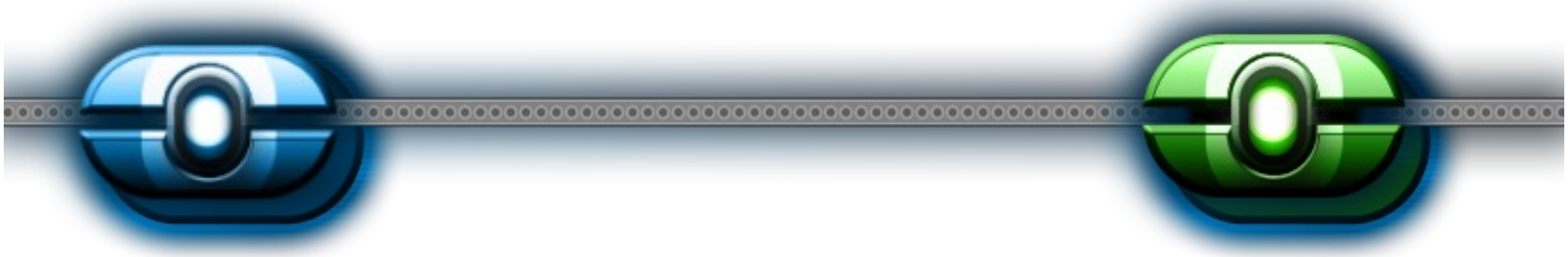
Services de sécurité

Vérifier que l'information n'a pas été altérée

Vérifier la légitimité de demande d'accès

Authentification

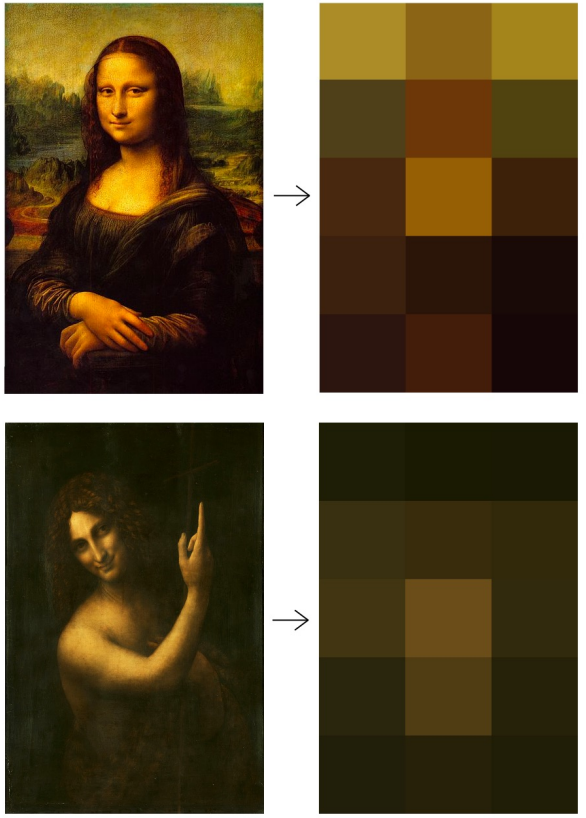
Intégrité



+ **non répudiation**: s'assurer que l'émetteur du message ne peut pas nier avoir émis le message dans le futur.

Fonction de hachage

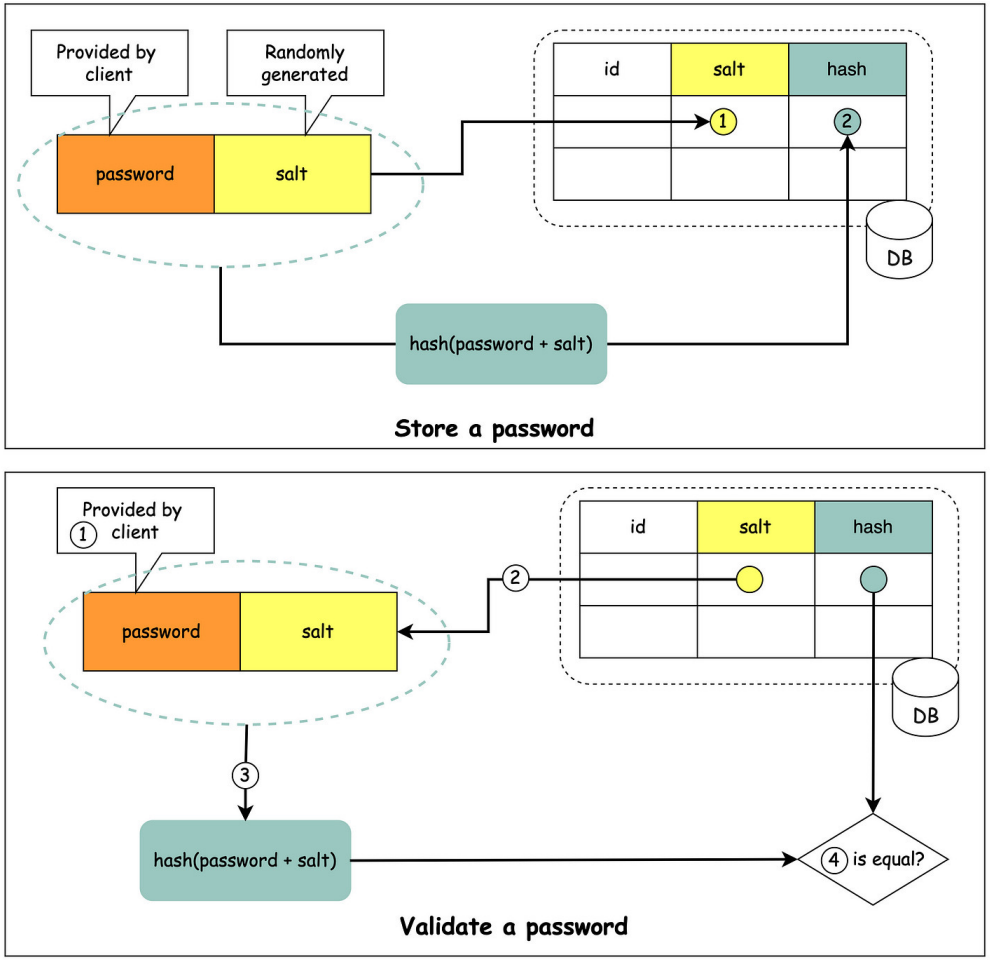
- Calculer une emprunte numérique (hash) souvent de petite taille afin d'identifier une donnée
  - **Sens unique:** impossible de construire une donnée à partir de son hash;
  - L'emprunte se calcule « très rapidement »;
  - Impossible de modifier la donnée sans modifier son hash;
  - Impossible de trouver deux données différents ayant la même hash.
- Applications :
  - Stockage des mots de passe
  - Intégrité (si le hash est échangé sur canal sûr!)
- Exemples : MD-4, MD-5, SHA-1, SHA-256, etc.



Source de l'image: Wikipedia

Question pratique: stockage des mots de passe

- A ne jamais stocker des mots de passe en clair
- Eviter de stocker des mots de passes chiffrés
- Pourquoi ne pas stocker que le hash ? → rainbow tables
- Solution recommandée:
  → **Hash "salés"**



Source de l'image: https://blog.bytebytego.com/p/how-does-https-work-episode-6

Signature numérique

- Processus qui permet de s'assurer de l'intégrité d'une donnée et d'en authentifier l'auteur sans qu'il ne puisse nier avoir émis la donnée (non répudiation)

- Ce **mécanisme repose sur la cryptographique asymétrique**
- La signature est calculée en utilisant la clé privée de l'émetteur
- La signature est vérifiée en utilisant la clé publique de l'émetteur

- On peut seulement chiffrer la donnée en utilisant la clé privée mais en pratique on chiffre une emprunte (hash) de la donnée.
- En pratique MD-5 + RSA, SHA256 + RSA, etc.

- Attention Signature → **intégrité, authentification et non répudiation**

Scellement

- Processus qui permet de s'assurer de l'intégrité d'une donnée et d'en authentifier l'auteur
- Ce **mécanisme repose sur la cryptographique symétrique**
- On appelle le résultat un sceau, un MAC (message authentication code) ou un MIC (message integrity code).

  Attention en réseau on préfère MIC pour éviter les confusions !

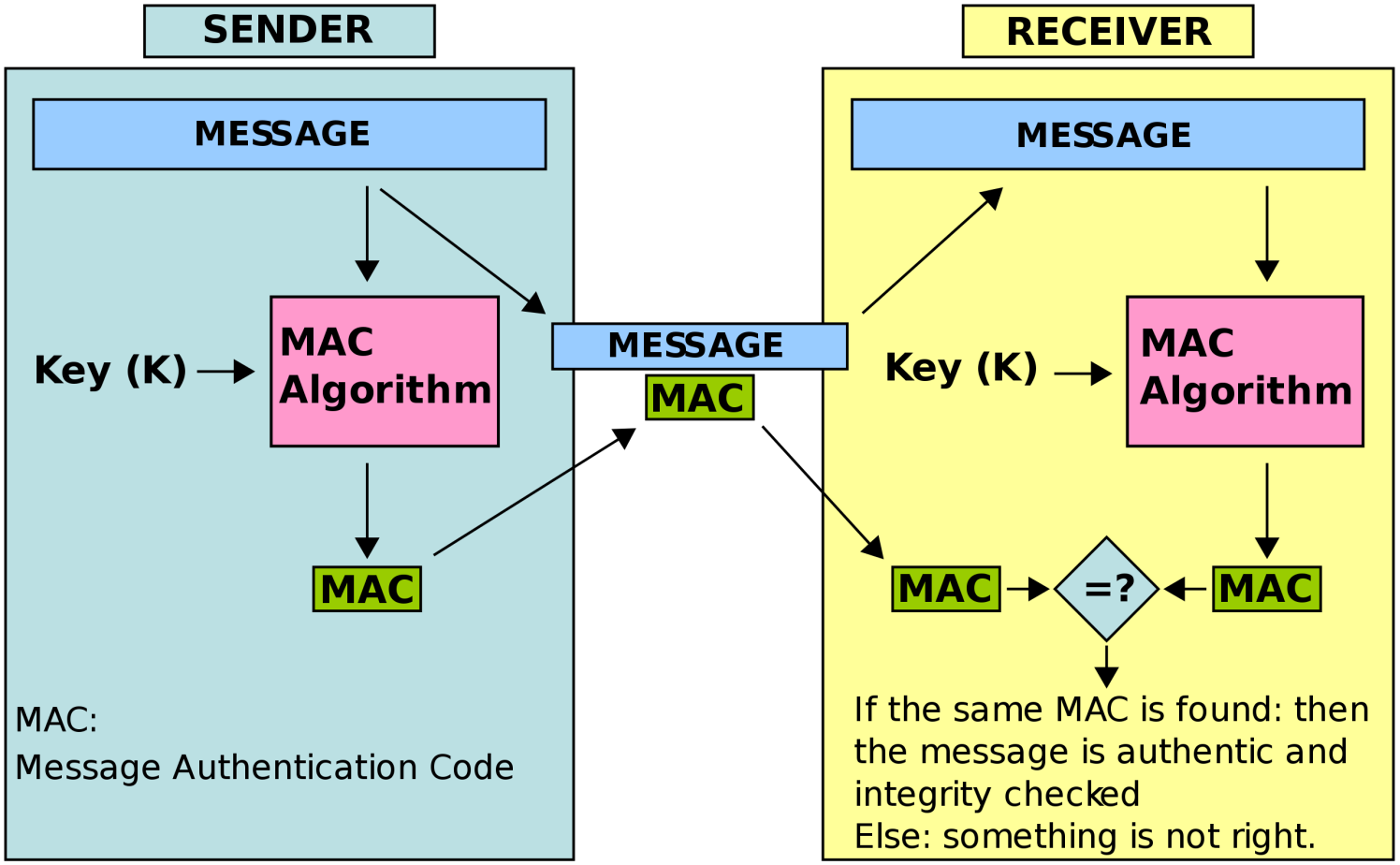
- En pratique le MIC est souvent calculé en utilisant des :

  HMAC : combine le message avec une clé secrète et applique une fonction de hachage (comme SHA-256) pour produire un code d'intégrité

  CMAC : découpe le message en blocs, chiffre chaque bloc avec une clé secrète, puis combine les blocs chiffrés pour générer le code d'intégrité

- Attention Scellement → intégrité et authentification

Scellement



Source: Wikipedia

Problème de distribution de clés

Distribution de clés symétriques / asymétriques

- **En cryptographie symétrique**
  - Pré-distribution
  - Canal sécurisé pour l'échange de clés (souvent en utilisant la crypto asymétrique)

- **En cryptographie asymétrique**
  - Par conception, seuls les clés publiques sont échangées
  - Par conception, il est **en pratique** "impossible" de déduire la clé privée à partir de la clé publique dans un temps raisonnable

  - Problème d'authenticité de clé publique !
  - Attaque MitM : Remplacer les clés publiques échangées par ses propres clés
  - Comment s'assurer que la clé publique est bien celle de l'entité avec laquelle on souhaite communiquer ?

  - Solution → **Infrastructure à clés publiques (PKI)**

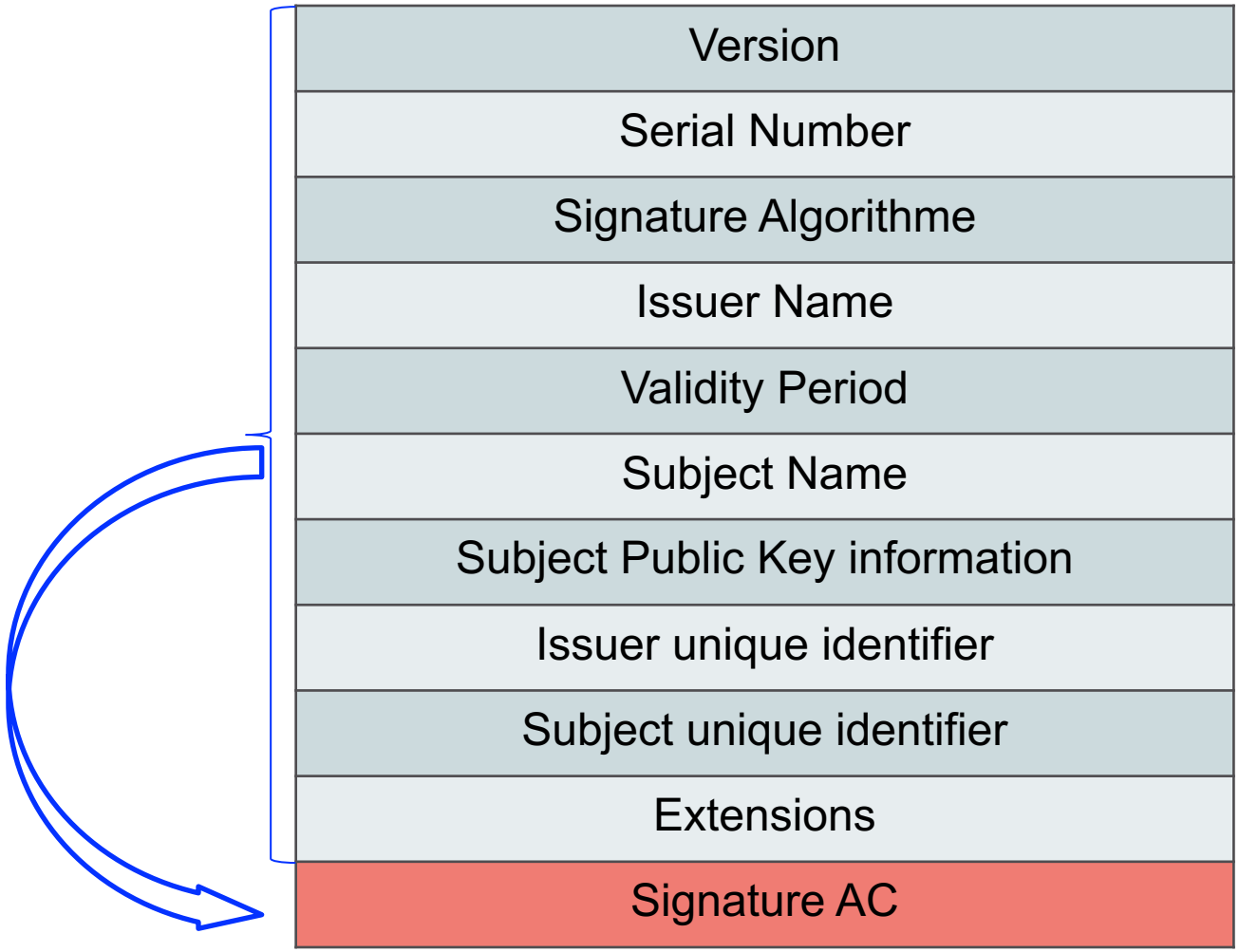
Infrastructure à clés publiques (PKI)

- Les autorités de certification
  - Tiers de confiance
  - La base du Transport Layer Security (TLS)
  - Utilisée aussi pour les signatures électroniques avancés
  - Format de certificats le plus rapandue: X.509 (RFC 52805)

- La solution la plus rapandue pour HTTPs, SMTP, Secure Modbus, etc.

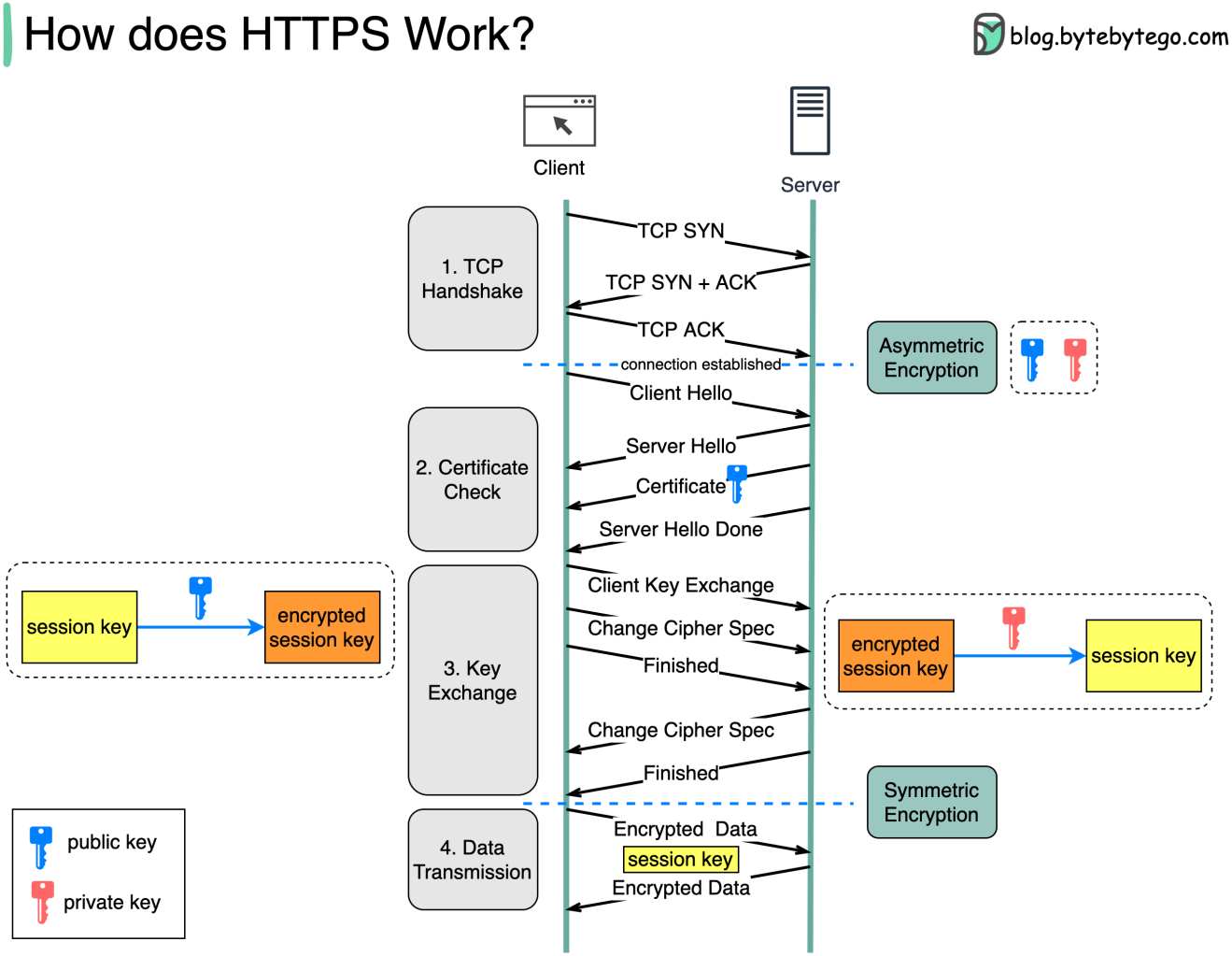
- Autres solutions:
  - La toile de confiance (PGP)
  - DANE/DNSSEC
  - Solutions à base de Blockchain

Certificat X.509



Exemple HTTPs/TLS

How does HTTPS Work?



Source: https://blog.bytebytego.com/p/how-does-https-work-episode-6

Introduction & Rappels

Réseaux sans fil

Classification des réseaux sans fil

- **Classification basée sur l'infrastructure**
  - **Les réseaux avec infrastructure**
    - Station de base, point d'accès, etc.
    - Généralement des réseaux mono-saut
    - Exemples: réseaux cellulaires, Wi-Fi
  - **Les réseaux ad-hoc**
    - Aucune infrastructure
    - Coordination et auto-organisation
    - Généralement des réseaux multi-sauts
    - Exemple: Wi-Fi direct, Réseaux de capteurs, etc.

Classification des réseaux sans fil

- **Classification basée sur la mobilité**
  - **Les réseaux statiques (fixes):**

    Pourquoi le sans fil ? coût, accessibilité des zones de déploiement, flexibilité, etc.

    Exemple: réseaux de capteurs statiques
  - **Les réseaux mobiles**

    Une partie des nœuds sont mobiles

    Plus de verrous scientifiques et techniques

    Ex: Réseaux cellulaires, réseaux de véhicules, flottes de robots, etc.

Classification des réseaux sans fil

➢ Classification basée sur la portée radio

– **Body Area Networks**

Réseau de capteurs corporel

– **Personal Area Networks**

Maison intélligente (Bluetooth, Zigbee, etc.)

– **Local Area Networks**

Wireless LANs (802.11, etc.)

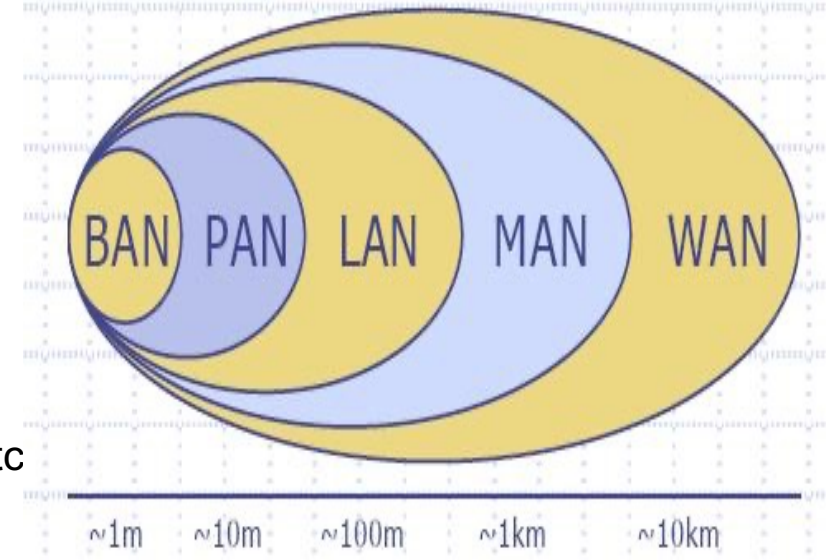
– **Metropolitan Area Networks**

Réseaux métropolitains (802.16, etc.)

– **Wide Area Networks**

Réseaux cellulaires (2G, 3G, 4G, 5G, etc

LP WAN (LoRa, SigFox, etc.)



Positionnement et objectif

Trois types de réseaux sans fil avec des caractéristiques différentes:

- **Réseaux locaux sans fil**
- ~~**Réseaux cellulaires**~~
- **Réseaux de capteurs sans fil (IoT)**

Objectif global:

- Comprendre l'architecture et les verrous des réseaux sans fil
- Comprendre les verrous de la sécurité des communications sans fil, quelques solutions, leurs limites, quelques travaux de recherche

Plan détaillé

- **Réseaux locaux sans fil: Wifi**
  - Généralités et architecture
    - Mode Infrastructure Vs Mode Ad-Hoc
    - Canaux WiFi
    - Politique d'accès au canal en 802.11
  - Sécurité des réseaux WiFi
    - Besoin de sécurité en WiFi
    - Protocole WEP: Principe, limites et attaques
    - Protocoles WPA/WPA2/WPA3: principe et attaques

Plan détaillé

- **Network Access Control**
  - Principe, AAA, 801.1X, EAP, mise en place

- **Réseaux de capteurs sans fil (IoT)**
  - Introduction aux réseaux de capteurs sans fil
  - Communication dans les RCSF
  - Économie d'énergie dans les RCSF

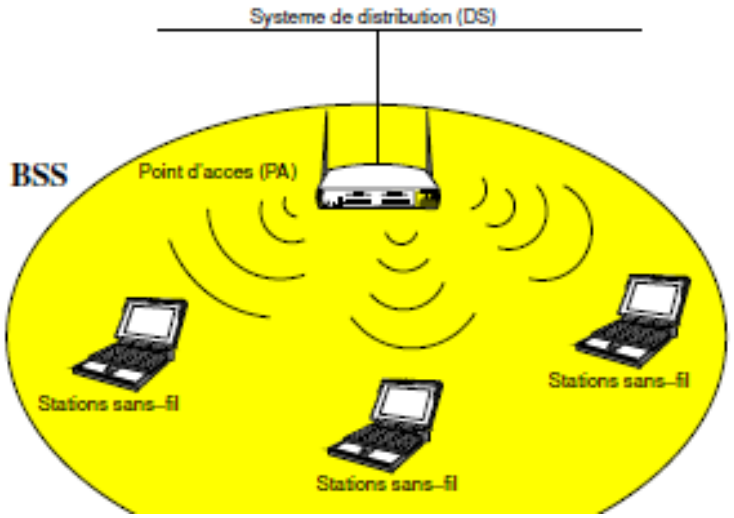
  - Principe de base de la sécurité dans les réseaux de capteurs
  - Contributions à la sécurité des réseaux de capteurs sans fil

Réseaux locaux sans fil (Wi-Fi)

Architecture et communication

Modes 802.11: mode infrastructure

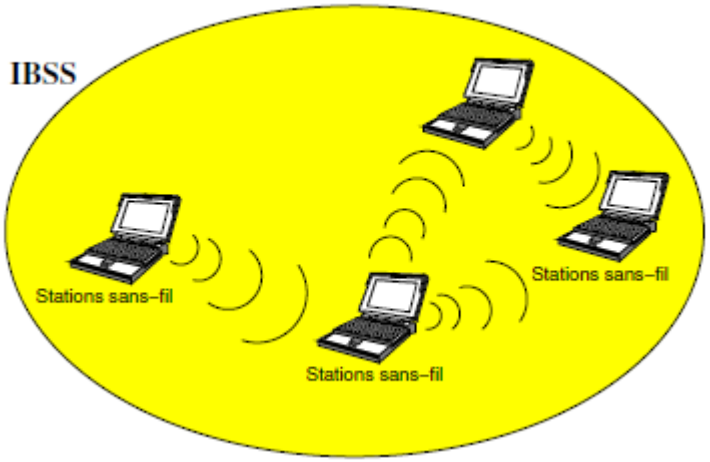
- Station spéciale appelée Point d'Accès (PA)
- Deux stations wifi se connectent entre eux via leur PA commun
- Une station se connecte au réseau via le PA.
- Les stations se trouvant a portée radio du PA forment un BSS (Basic Service Set).
- Chaque BSS est identifié par un **BSSID** (adresse MAC du PA)



Modes 802.11: mode Ad-Hoc

- Fonctionnement totalement distribué sans infrastructure
- Pas d'éléments structurant hiérarchiquement la cellule
- Chaque station joue aussi le rôle d'un routeur
- Les stations se trouvant a portée radio forment un **IBSS** (Independant Basic Service Set)
- Une station joue le role d'un AP virtuel
- IBSS ID: @ MAC du AP virtuel

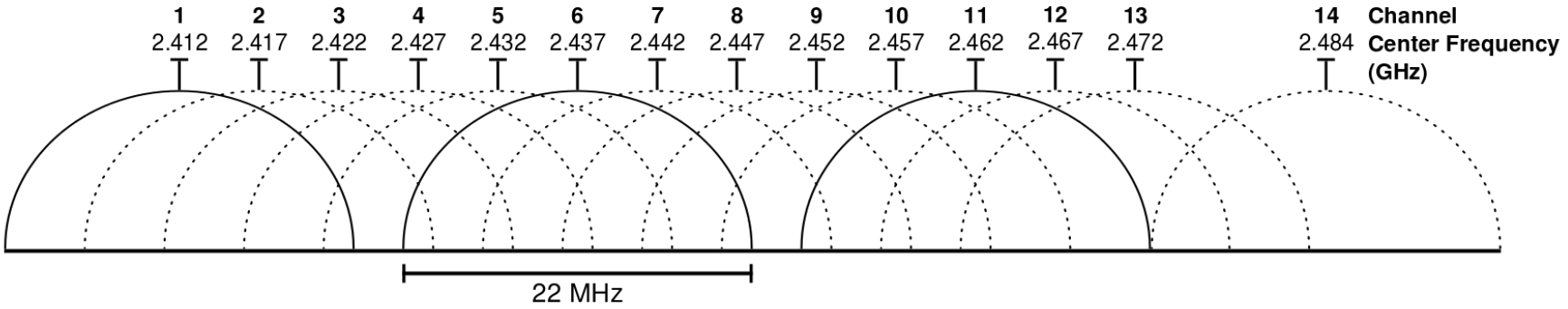
- Utilisé pour les réseaux de terrain



Couche Physique: cannaux 802.11

- **Bande ISM 2.4 et 5 GHz:**
  - Bande 2.4GHz: 2.4 à 2.5 GHz (2.400 à 2.483 en Europe)
  - Bande des 5GHz: 5.725-5.875 GHz
  - Division en canaux de 20 ou 22 Mhz

- **Exemple: Liste des canaux 802.11 (2.4G)**



- **Canaux sans chevauchements : 3(2.4 GHZ) Vs 26 (5Ghz)**

Standards 802.11

Standard	Date de sortie	Fréquence	Largeur de bande	**Débit maximal**	Modulation
		(GHz)	(MHz)	**(Mbit/s)**	
802.11	1997	2.4	22	**2**	DSSS, FHSS
802.11a	1999	5	20	**54**	OFDM
		3.7			
802.11b	1999	2.4	22	**11**	DSSS
802.11g	2003	2.4	20	**54**	OFDM
802.11n	2009	2.4/5	20	**65**	MIMO-OFDM
			40	**135**	
802.11ac	2014	5	20	**86.7**	
			40	**180**	
			80	**390**	
			160	**780**	
802.11ax	2020	2.4/5		**10 000**	MIMO-OFDMA

MAC 802.11 DCF: CSMA/CA

- Ecouter le canal (Carrier Sense) pendant DIFS. S'il est libre transmettre et attendre un acquittement explicite sinon attendre qu'il soit libre + DIFS
- Si le timeout est atteint, aller à la **Procédure Backoff**
- **Procédure Backoff en 802.11:**
  - Initialise un temporisateur avec une valeur aléatoire entre 0 et W_max (initialement égale à 7);
  - Décrémente le temporisateur tant que le support est libre (si le support est occupé, le décompte est bloqué)
- Quand la valeur est nulle, émettre et attendre un acquittement explicite
- Si le timeout est atteint, Aller à la **Procédure Backoff** en doublant la valeur max du temporisateur (W_max=W_max*2)

MAC 802.11 PCF: Point Coordination Function

- Supportée dans le mode Infrastructure seulement
- Prioritaire sur le DCF mais très peu implémentée

- Le AP envoie périodiquement des trames de balise : diviser le canal en période CFP (contention-free period) et PC (contention period)

- Durant la CFP, le point d'accès interroge les stations à tour de rôle

- Conçue pour la transmission de données sensibles (applications de type temps réel: voix, vidéo, etc.)
- Accès assuré mais performances plus faibles

Contrôle d'erreurs (CRC)

- Basé sur des calculs de division de polynôme à coefficient dans {0,1}
- Utilisation de **polynômes générateurs** possédant des propriétés mathématiques particulières :
  - CRC-12 = $x^{12} + x^{11} + x^3 + x^2 + x + 1$
  - CRC-16 = $x^{16} + x^{15} + x^2 + 1$
  - CRC-32 = $x^{32} + x^{26} + x^{23} + x^{22} + x^{16} + x^{12} + x^{11} + x^{10} + x^8 + x^7 + x^5 + x^4 + x + 1$
- Exemples: Ethernet : CRC-32, ZIP CRC-16 ou 32
- Calcul du CRC en émission :
  - Ajouter m zéros au mot binaire à émettre (m: degré du polynôme générateur)
  - Effectuer une division euclidienne du mot obtenu par le polynôme générateur
  - Le reste de la division correspond au CRC à ajouter au mot avant de l'émettre

* Claude Duvallet, les codes correcteurs et les codes détecteurs, cours maitrise informatique

Contrôle d'erreurs (CRC)

- Exemple: CRC-4, polynôme générateur x^4+X^2+x (10110)
- Mot binaire à émettre : **1 1 1 1 0 1 1 1 0 1**

x^{13}	x^{12}	x^{11}	x^{10}		x^8	x^7	x^6		x^4			x^4	$+x^2$	$+x$
x^{13}		x^{11}	x^{10}											
	x^{12}				x^8	x^7	x^6		x^4			x^9	$+x^8$	$+x^6$
	x^{12}		x^{10}	x^9								$+x^5$	$+x^3$	$+x^2$
			x^{10}	x^9	x^8	x^7	x^6		x^4			$+x$		
			x^{10}		x^8	x^7								
				x^9			x^6		x^4					
				x^9		x^7	x^6							
						x^7			x^4					
						x^7		x^5	x^4					
								x^5						
								x^5		x^3	x^2			
										x^3	x^2			

- CRC = x^3+x^2 = 1100 → émettre 1111011101 1100

* Claude Duvallet, les codes correcteurs et les codes détecteurs, cours maitrise informatique

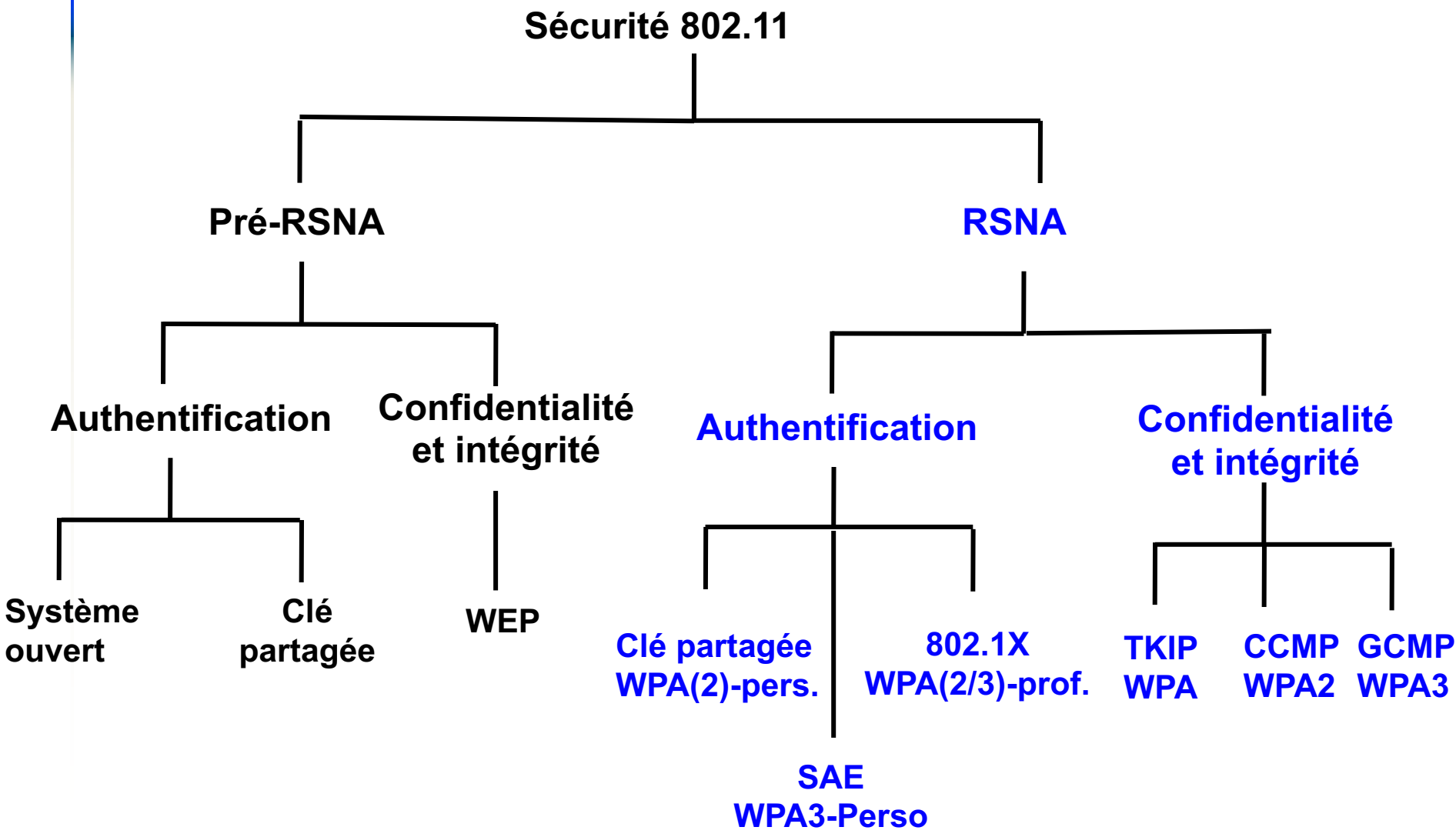
Réseaux locaux sans fil (Wi-Fi)

Sécurité

Besoin de sécurité Wi-Fi

- Transmission sans fil –> les transmissions peuvent facilement être écoutées par un analyseur indétectable
- Types d'attaques
  - Ecoute
  - Modification de messages (contenu, adresse IP, etc.)
  - Injection de paquets
  - Dénis de service (brouillage, désassociations), etc.
- Chiffrement nécessaire(confidentialité)
- Besoin d'authentification et d'intégrité

Sécurité Wifi: Résumé



Wired Equivalent Privacy (WEP)

- Une clé secrète pré-chargée par l'administrateur
- Taille : **40, 104 ou 232 bits** (5,13 ou 29 octets)
- Exemples:

  1A648C9FE2, 'XYZ12'

  99D767BAC38EA23B0C0176D152
- La même clé pour l'authentification et le chiffrement
- L'utilisation du WEP est optionnelle

- Ajout d'un vecteur d'initialisation **IV** de **24 bits (3 octets)** pour former une clé de 64, 128 ou 256 bits
- Exemple (128bits): IV= K[0] || K[1] || K[2], clé secrète = K[3] || … || K[15]

Authentification WEP

- Authentification « Open System »:
  - La station envoie son ID et le point d'accès renvoie la réponse d'authentification;
- Authentification à clé partagée (PSK):
  - La station envoie une requête d'authentification au point d'accès (AP);
  - Le point d'accès envoie un texte en clair (128 octets) pour un challenge;
  - La station client doit chiffrer le texte en clair en utilisant la clef WEP et la renvoyer a l'AP;
  - Le point d'accès déchiffre le texte et le compare au texte en clair envoyé et renvoie une réponse positive ou négative;
  - Après authentification et association, WEP peut être utilisé pour chiffrer les données.

Authentification WEP





Auth Request

Challenge r (random)

$E_K(r)$

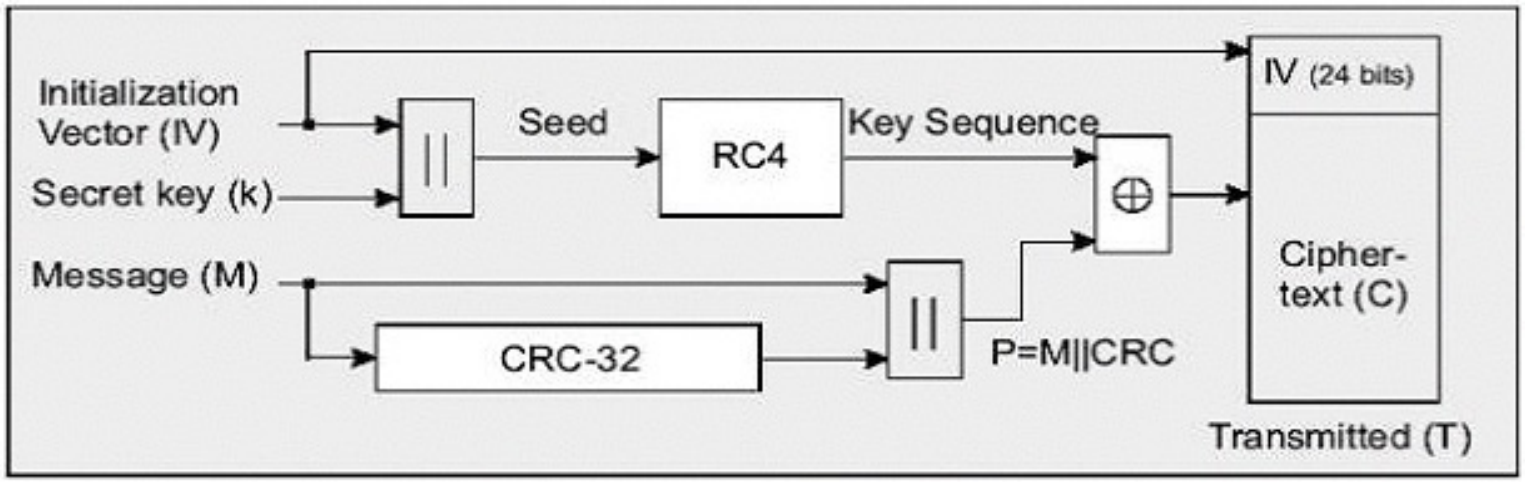
$D_k(E_K(r)) = r$?

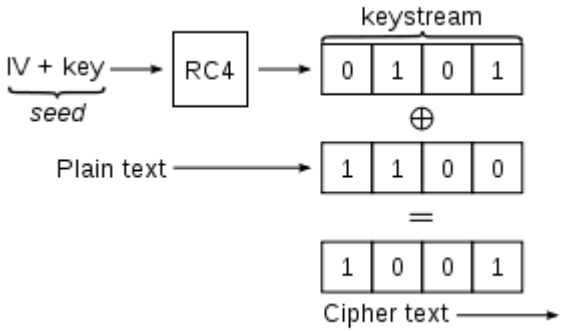
authenticate success /

authenticate failure

Confidentialité et intégrité WEP: RC4/CRC

- Algorithme de chiffrement par flot RC4 (clef de 40, 104 ou 232 bits)





- Somme de contrôle CRC-32

Confidentialité et intégrité WEP:

- Pourquoi un IV différent par paquet alors qu'il est transmis en clair ?

…. et si on utilisait le même IV ?

- Plus de détails plus loin ☺

Confidentialité WEP: RC4 – juste pour info

- **Principe général :**

  Génération de l'aléa à partir d'un tableau d'état S_i de 256 octets

- **Initialisation du tableau à partir de la clé K**

  Pour i de 0 à 255, $S_i = i$

  Pour i de 0 à L: (K_i = octet i de la clé K)

  j = 0

  pour i de 0 à 255

  $j = (j + S_i + K_{(i \bmod L)}) \bmod 256$

  Échanger S_i et S_j

- **Génération de l'aléa :**

  $i = (i+1) \bmod 256$, $j = (j + S_j) \bmod 256$

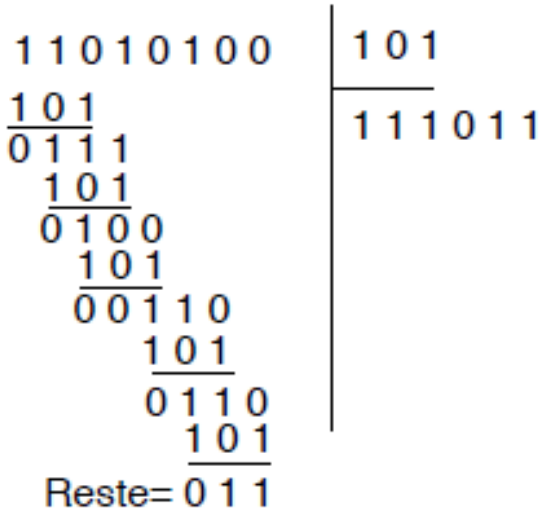
  Échanger S_i et S_j

  $t = (S_i + S_j) \bmod 256$ => sortir S_t

Intégrité WEP:CRC

- Basé sur des calculs de division de polynôme à coefficient dans {0,1}
- **Ex (CRC-2):**

6 bits de données: 110101 , Polynôme générateur 101 : x^2+1



On envoie E= 110101 11

- Exemples: Ethernet , WEP (CRC-32), ZIP (CRC-16 ou 32)

Failles du WEP

A- Fausse authentification basée sur une authentification valide

B- Attaque par rejeu

C- Modification / injection des paquets

D- Facilité de retrouver la suite chiffrante →

- ❑ Possibilité de « décrypter » des paquets (sans posséder la clé)
- ❑ Possibilité d'injecter des paquets
- ❑ Mener des fausses authentifications

E- Possibilité de retrouver la clé initiale « rapidement »

Failles du WEP: Pourquoi ?

- Schéma d'authentification très simple
- Chiffrement symétrique par flot
- Faible taille des Vecteurs IV
- Utilisation du CRC comme mécanisme pour assurer l'intégrité (linéarité du CRC)
- Aucun mécanisme anti-rejeu
- Utilisation de la clé initiale comme clé de session (pas de clés temporaires)

Attaques contre WEP(A): fausse authentifcation

- **Approche challenge-response :**

  STA –> AP : authenticate request

  AP –> STA : 128 byte authenticate challenge (c)

  STA –> AP : authenticate response IV,E(c) = c ⊕ RC4(IV || K)

  AP –> STA : authenticate success or failure

  …

  L'attaquant peut calculer c ⊕ (c ⊕ KS) = KS

  AP → attaquant: c'

  attaquant → AP: IV | c' ⊕ c ⊕ (c ⊕ KS) = c' ⊕ KS

- **L'authentification est dans un seul sens:**

  – AP ne s'authentifie pas auprès de STA

  – STA risque de s'associer à un AP malveillant

Attaques contre WEP (B/C): rejeu et modification

- **Attaque par rejeu :**
  - WEP ne donne pas de recommandation sur le choix de IV
  - IV est transmis en clair

    → possibilité de rejouer des anciens messages

- **Modification de paquets (linéarité du CRC) :**

$$CRC(X \oplus Y) = CRC(X) \oplus CRC(Y)$$

- L'attaquant écoute $E(M)=(M \mid CRC(M)) \oplus KS$, KS est la sortie de RC4
- Pour chaque ΔM, l'attaquant peut calculer $CRC(\Delta M)$ et ainsi :

$$((M \mid CRC(M)) \oplus KS) \oplus (\Delta M \mid CRC(\Delta M)) =$$

$$((M \oplus \Delta M) \mid (CRC(M) \oplus CRC(\Delta M))) \oplus KS =$$

$$((M \oplus \Delta M) \mid CRC(M \oplus \Delta M)) \oplus KS$$

Attaques contre WEP (D): retrouver la suite chiffrante

- **Conséquences:**
  - Pouvoir « décrypter» des paquets utilisant des IV compromis. Ex: débit de 11Mbps + taille moyenne de 1500 octets → 1 collision chaque 5 heures
  - Injecter des paquets valides dans le réseaux.
  - Mener des fausses authentifications

- **Attaque1: Exploiter la réutilisation des vecteurs d'initialisations**
  - La taille de IV est très faible (24 bits)
  - Pour un vecteur d'initialisations de 24 bits + Clé unique → 16777216 couples (IV, key stream) possibles
  - En connaissant le texte en clair d'un message M (requête ARP, DHCP, etc.), son chiffré (IV, Enc(M)), le key stream associé peut être déduit

Attaques contre WEP (D): retrouver la suite chiffrante

- **Attaque 2: Attaque inductive (KoreK chopchop attack):**
  - Récupération des n premiers octets de la suite chiffrante (messages des protocoles connus ARP, DHCP)
  - Découverte de la totalité de la suite chiffrante (grâce au calcul du code d'erreur CRC32), répéter pour chaque octet:
    1- Générer un message de taille n-3 octets entraînant une réponse prévisible
    2- Calculer le CRC (4 octets) de ce message et considérer les 3 premiers octets.
    3- Transmission du message obtenu (n-3 + 3 octets) chiffré concaténé à un octet supplémentaire construit par recherche exhaustive (255 valeurs).
    4- XOR entre le 4 octet du CRC et le (n+ 1) octet valide
  - Existe une variante qui se base sur une déduction dans le sens inverse (variante implémentée sous aircrack-ng)

Attaques contre WEP (E): retrouver la clé

- **Attaque par brute force:**
  - Essayer toutes les combinaisons possibles
  - Clés 64/**40** bits → Une dizaine d'heures avec un simple ordinateur

- **Attaque par dictionnaire:**
  - Plus adaptée aux clés 128 et 156 bits
  - Pas de contrôle de robustesse/validité des clés choisies par les utilisateurs

Attaques contre WEP (E): retrouver la clé

➢ Attaque FMS (Fluhrer, Mantin and Shamir): les clés faibles

- Pour quelques clés WEP, le début de la suite chiffrante donnée par RC4 n'est pas uniformément aléatoire
- Rappel: Clé K en entré du RC4=24 bits d'IV + Clé secrète (40,104 ou 232 bits)
- Si des clés faibles sont utilisées, le début de la suite chiffrante donne beaucoup d'informations sur la clé WEP (découverte plus raide de la clé)

  → Récupérer IV (K[0],K[1] et K[2]) + premier octet du keystream.

  → Pour ces clés faibles, l'attaquant peut retrouver K[3] avec une probabilité de 5 % (au lieu de 1/256 dans le cas uniforme).

  → Une fois K[3] trouvée, trouver K[4], etc.
- La clé WEP (128) peut être calculée (proba > 50%) en écoutant 4 à 6 millions paquets !!!

Attaques contre WEP (E): retrouver la clé

- **Attaque de Koreck (Amélioration et extension de FMS):**
  - 16 corrélations supplémentaires entre les premiers octets de la clé et les deux premiers octets de suite chiffrante.
  - Accélérer le calcul de clé WEP
  - La clé WEP (128) peut être calculée (proba > 50%) en écoutant environ 700 000 paquets !!!

Attaques contre WEP (E): retrouver la clé

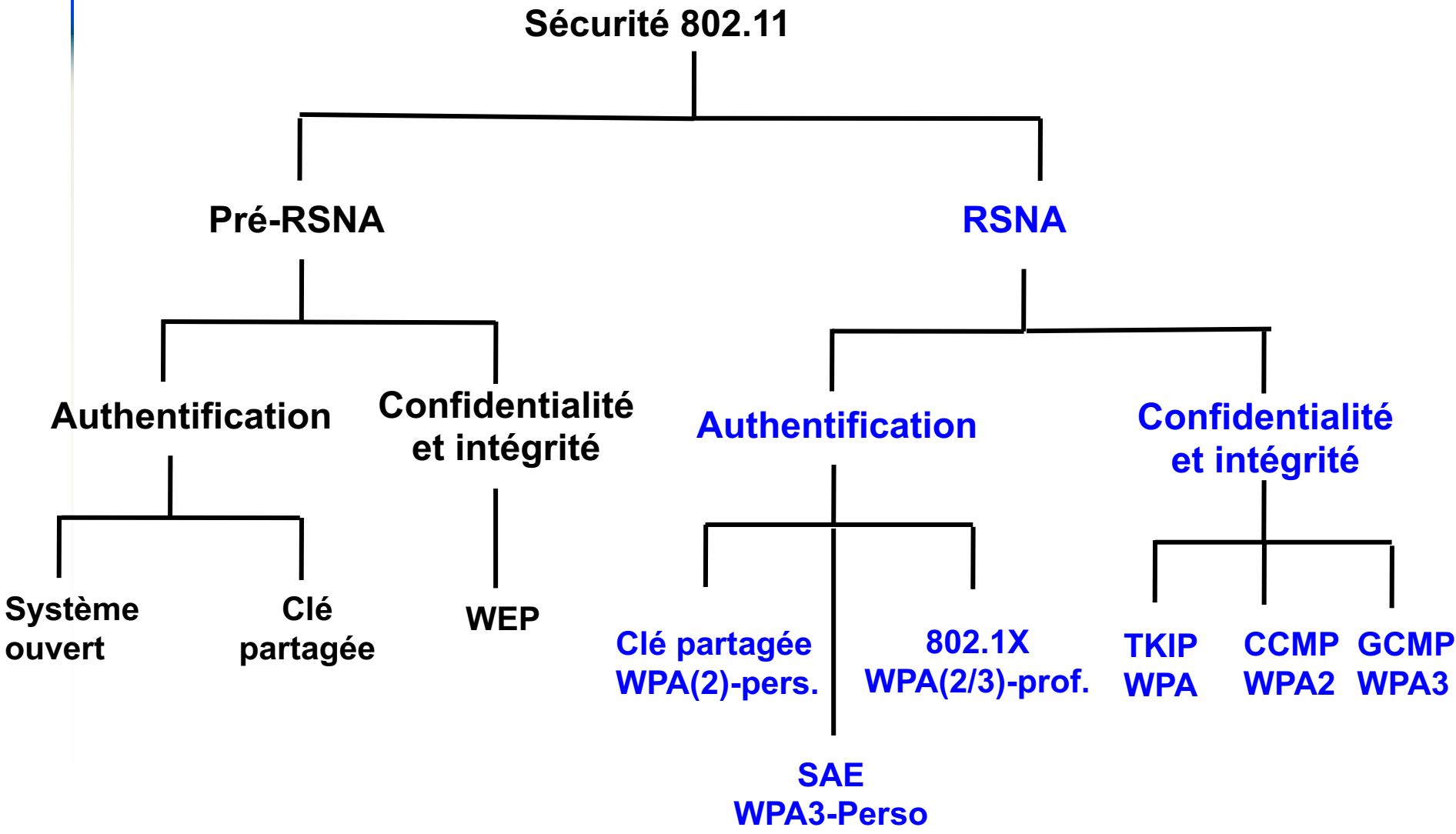
- **Attaque de PTW (Physkin, Tews and Weinmann) :**
  - Même principe que FMS et Koreck avec deux différences majeures:
    - De nouvelles corrélations sont exploités: corrélation de Klein et Jenkins qui impliquent toutes les clés et non seulement les clés faibles
    - Le vote se fait sur la totalité de la clé et non pas octet par octet
  - La clé WEP peut être calculée (proba > 50%) en écoutant 35000 à 40000 paquets !!! Quelques secondes sur simple ordinateur !!!

→ Attaques FMS, Koreck PTW: **complexité linéaire** en fonction de la taille des clés

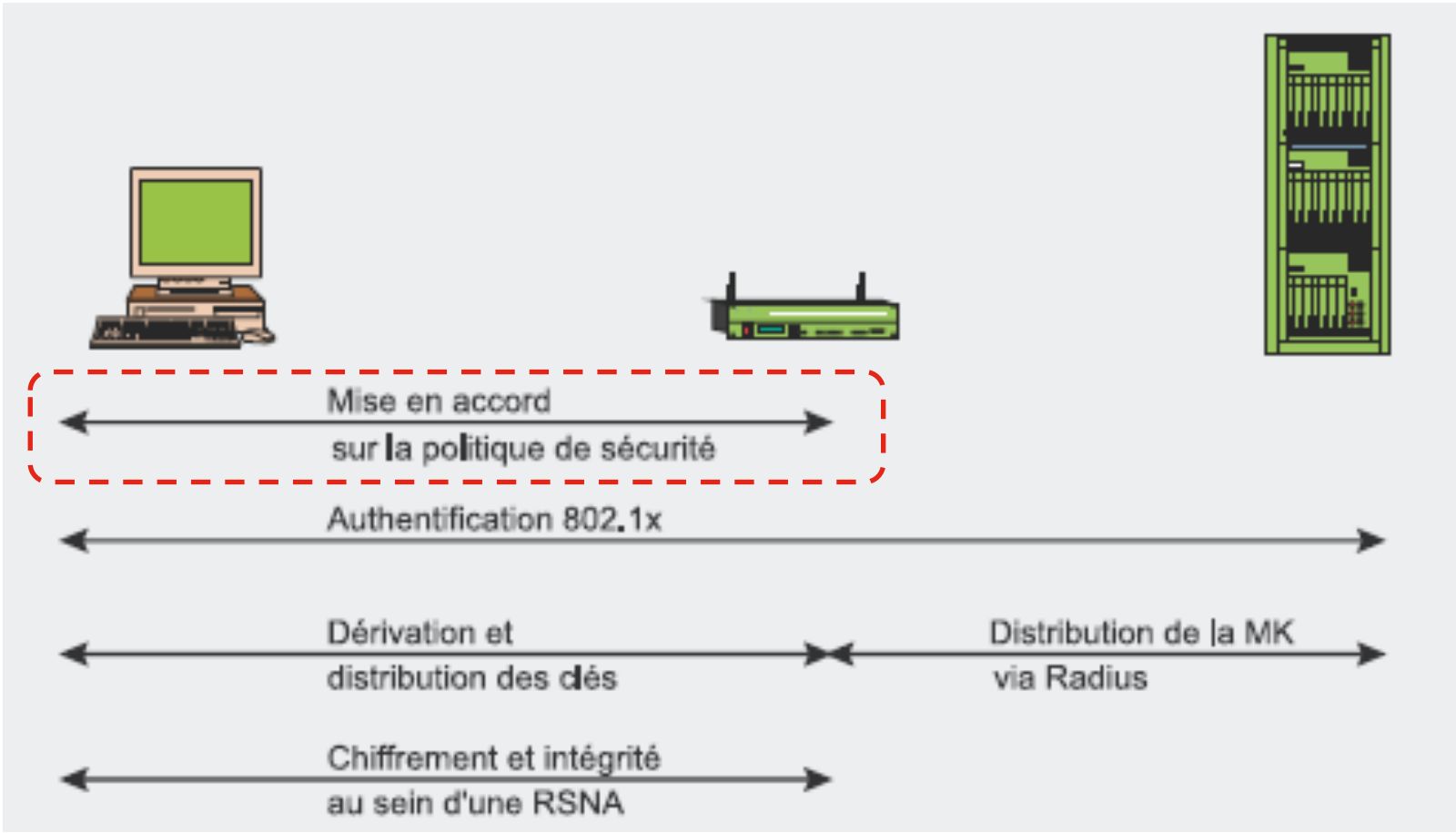
La norme 802.11i

- Une architecture de sécurité robuste (RSN: Robust Security Network)
- Séparation de l'authentification utilisateur et du chiffrement / intégrité
- 2003: WPA : deuxième génération, comptabilité avec WEP, sous ensemble de la norme 802.11i (algo TKIP – Temporal Key Integrity Protocol)
- 2004: WPA-2: troisième génération et changement de paradigme (Algo CCMP – Counter-Mode/Cipher Block Chaining Message Authentication Code Protocol)
- 2018/2019 : WPA3: quatrième génération Remplacement du PSK par SAE + renforcement du chiffrement

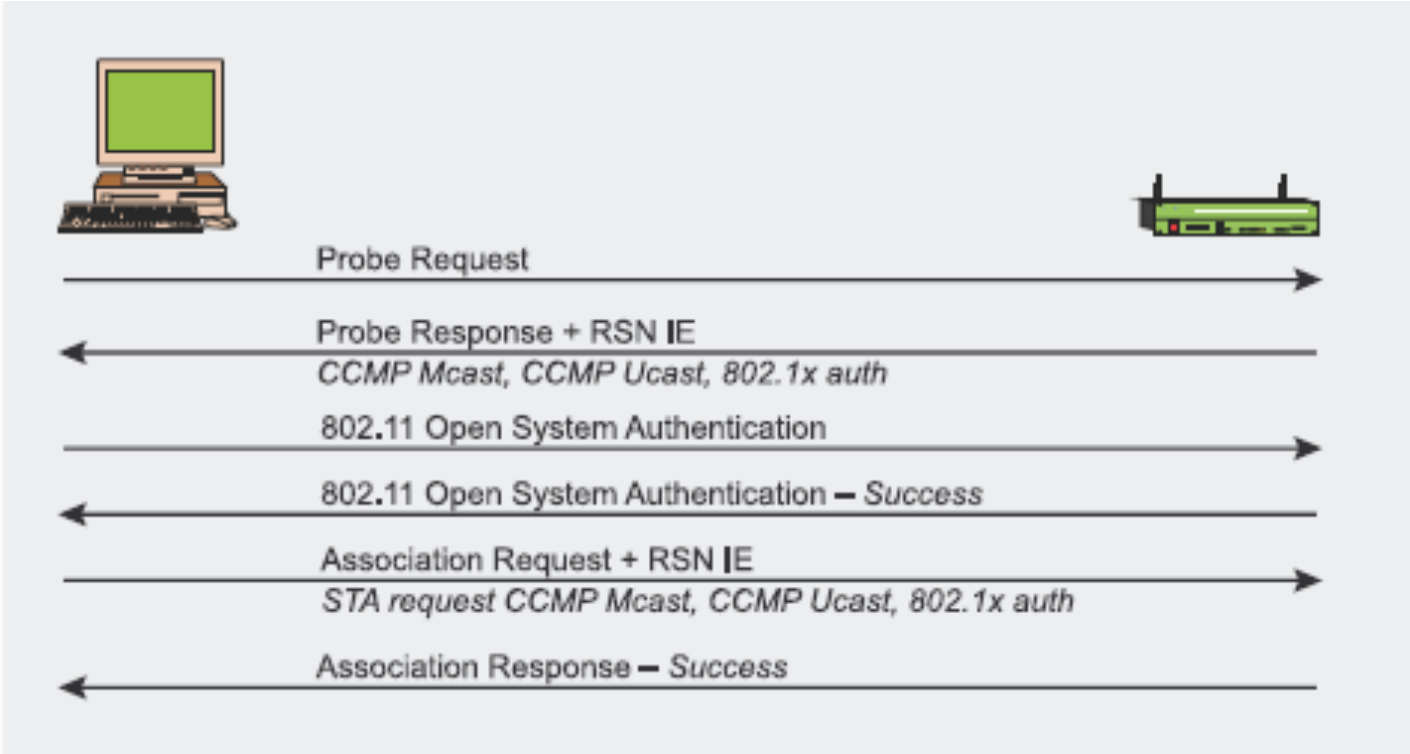
Sécurité Wifi: Résumé



La norme 802.11i: Phases opérationnelles

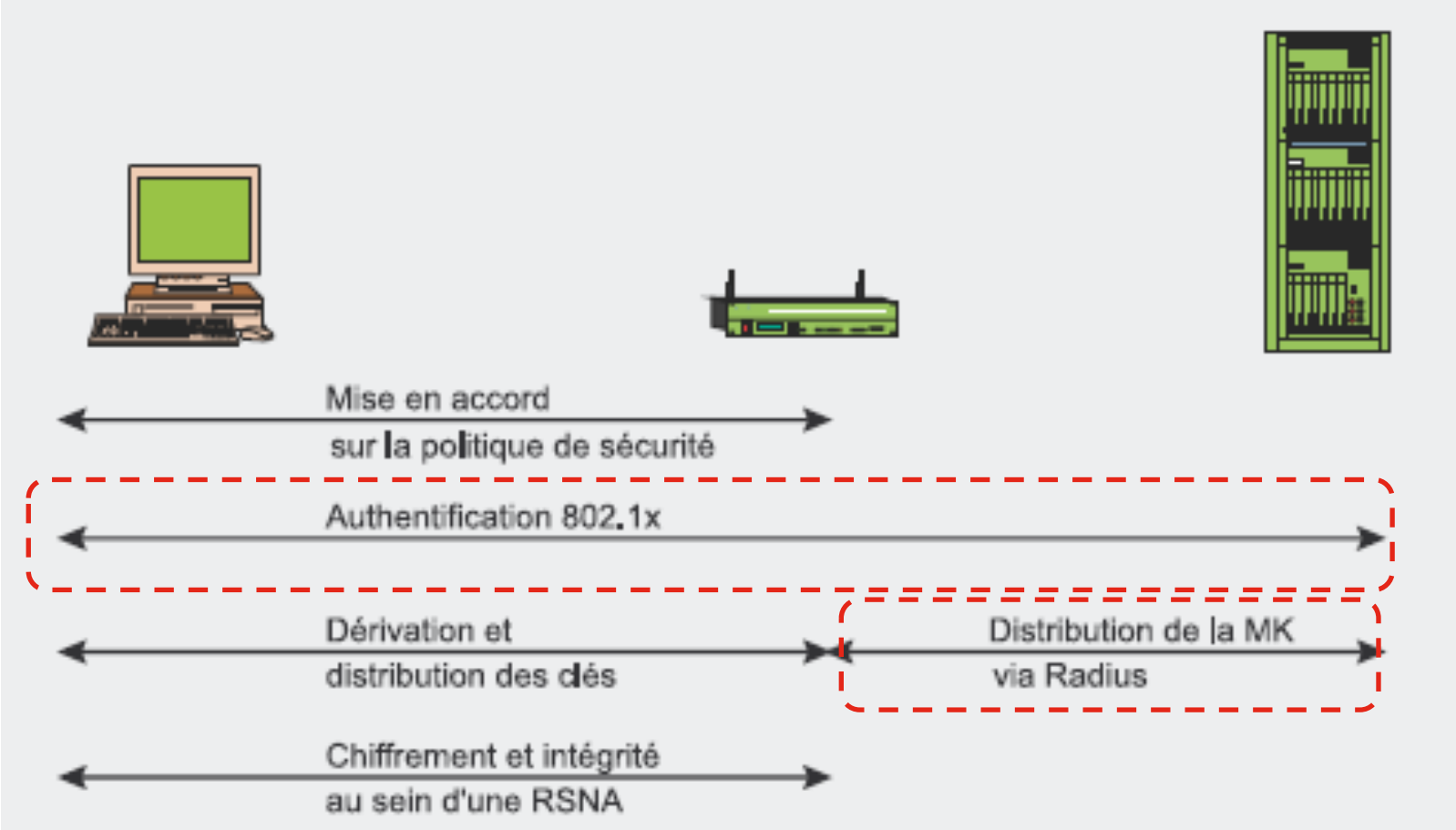


Phase 1: Mise en accord sur la politique de sécu

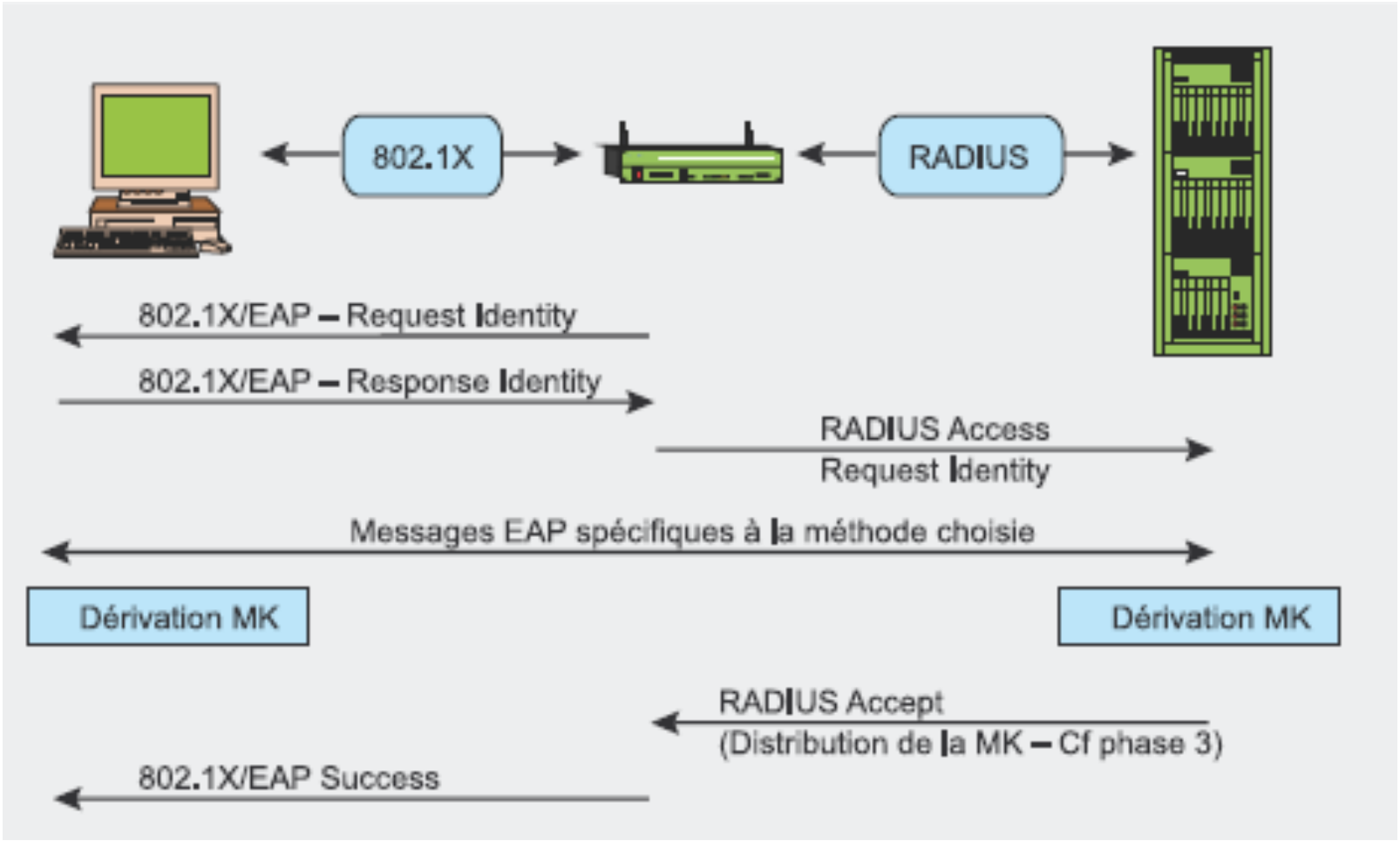


RSN IE:
- Méthode d'authentification (802.1X, clé-pré partagée PSK)
- Protocole de chiffrement unicast (CCMP, TKIP, etc.)
- Protocole de chiffrement multicast (CCMP, TKIP, etc.)

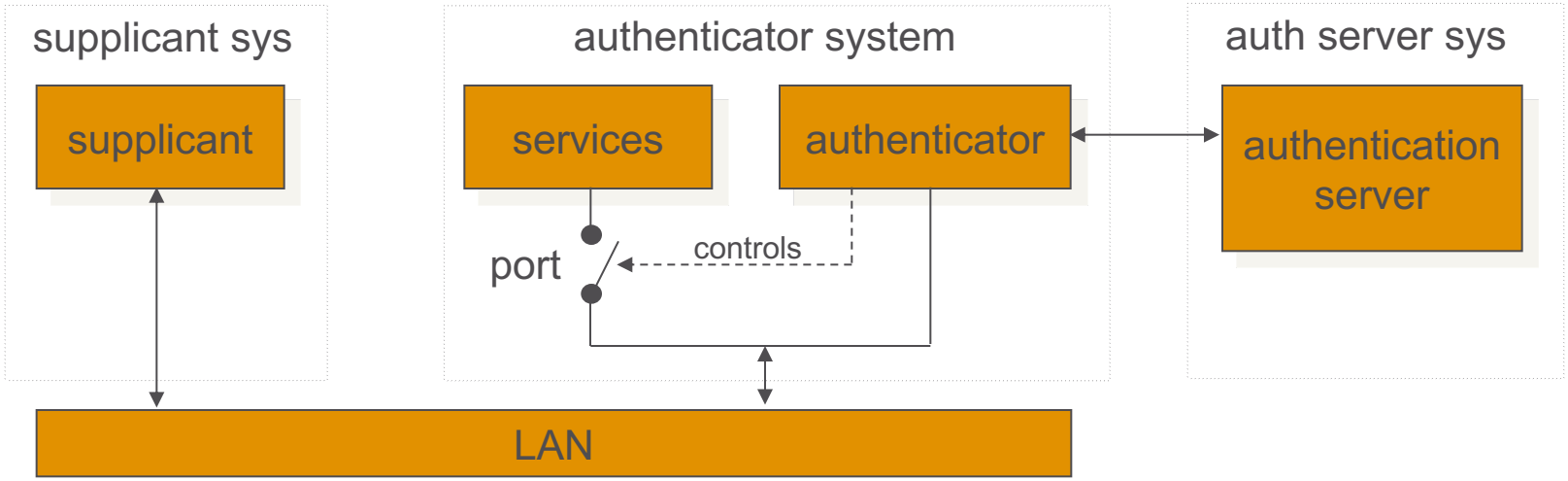
La norme 802.11i: Phases opérationnelles



Phase 2: Authentification 802.1X (optionnel)



Phase 2: modèle d'authentification 802.1X



- Le client (supplicant) demande l'accès à un service (se connecter au réseau)
- Le contrôleur (authenticator) contrôle l'accès au service (l'état du port)
- Le serveur d'authentification (authentication server) autorise l'accès au service

Phase 2: Correspondence 802.1X / WiFi 802.11i

- Supplicant → Station mobile (STA)
- Authenticator → Point d'accès (AP)
- Authentication server → Serveur qui s'exécute sur le point d'accès ou sur une machine dédiée

- En plus 802.11i intègre:
  - Une authentification réussie se termine par l'envoi d'une clé de session en plus de la réponse positive de l'authentification

Phase 2: 802.1X et EAP

- **EAP (Extensible Authentification Protocol) [RFC 3748]**
  - Protocole conçu pour le transport de messages d'authentification (e.g., MD5, PSK, TLS, TTLS, PEAP, etc.)
  - Quatre types de messages:
    - EAP request –supplicant → authentication server
    - EAP response –authentication server → supplicant
    - EAP success –successful authentication
    - EAP failure –authentication failure
  - Contrôleur joue un rôle passif et ne connait pas le contenu des messages, il reconnait seulement EAP success and failure

Exemple de méthodes d'authentification Radius

Radius-MAC => Authentification par adresses MAC → Pas recommandé et surtout en sans fil

EAP-MD5 => pas d'authentification mutuelle entre client et le serveur Radius, le client s'authentifie par mot de passe

EAP-PSK => authentification mutuelle entre client et le serveur par secret partagé

EAP-TLS => Authentification mutuelle par certificats

- TLS Handshake - Authentification mutuelle par certificats
- L'identifiant dans la base est le CN du certificat

Exemple de méthodes d'authentification Radius

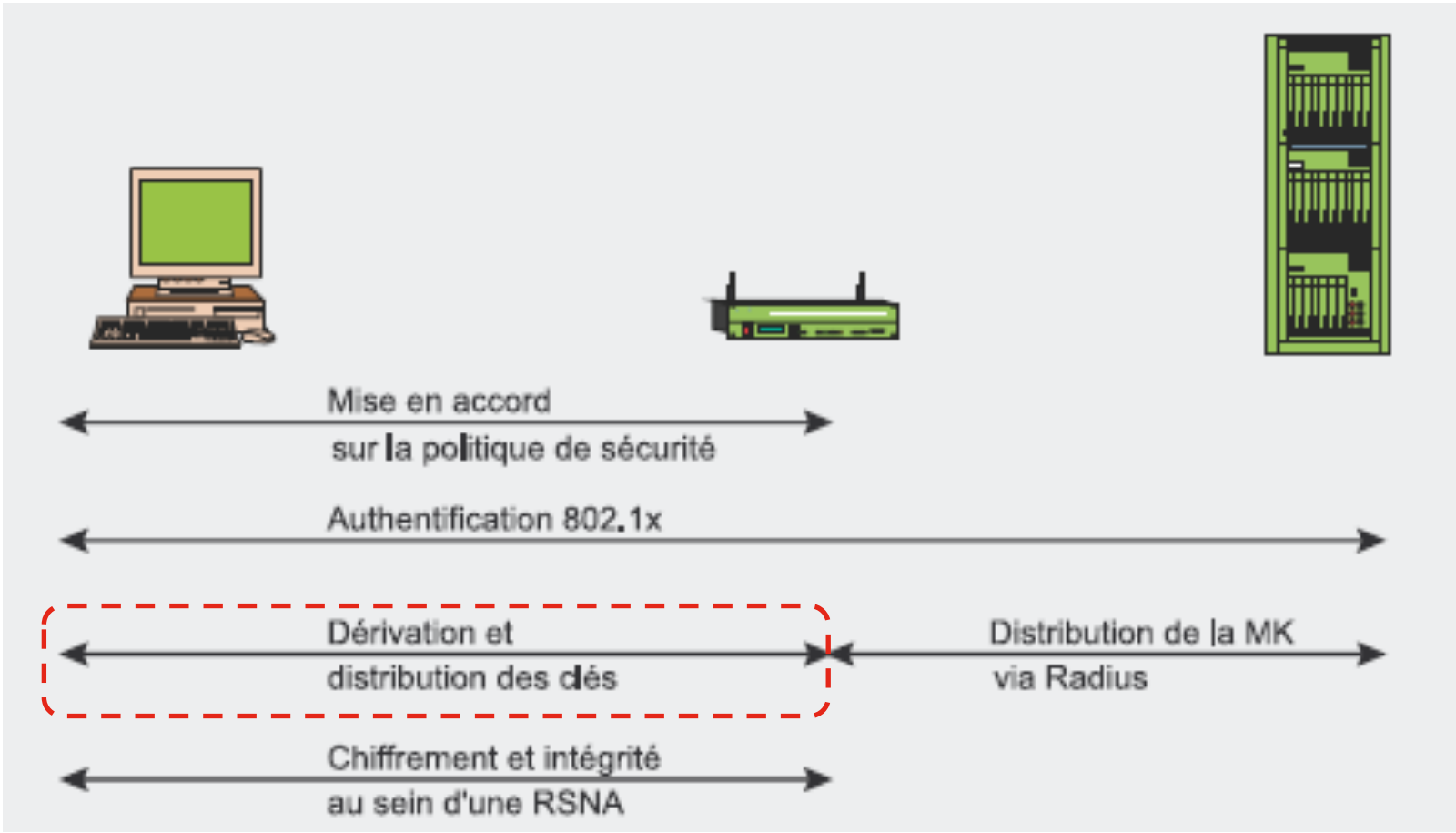
EAP-TLS => **problème**
nécessité de distribuer des certificats à tous les utilisateurs ou machines

EAP-TTLS et PEAP => Authentification du serveur par son certificat et Authentification du client par login/password

Deux phases :

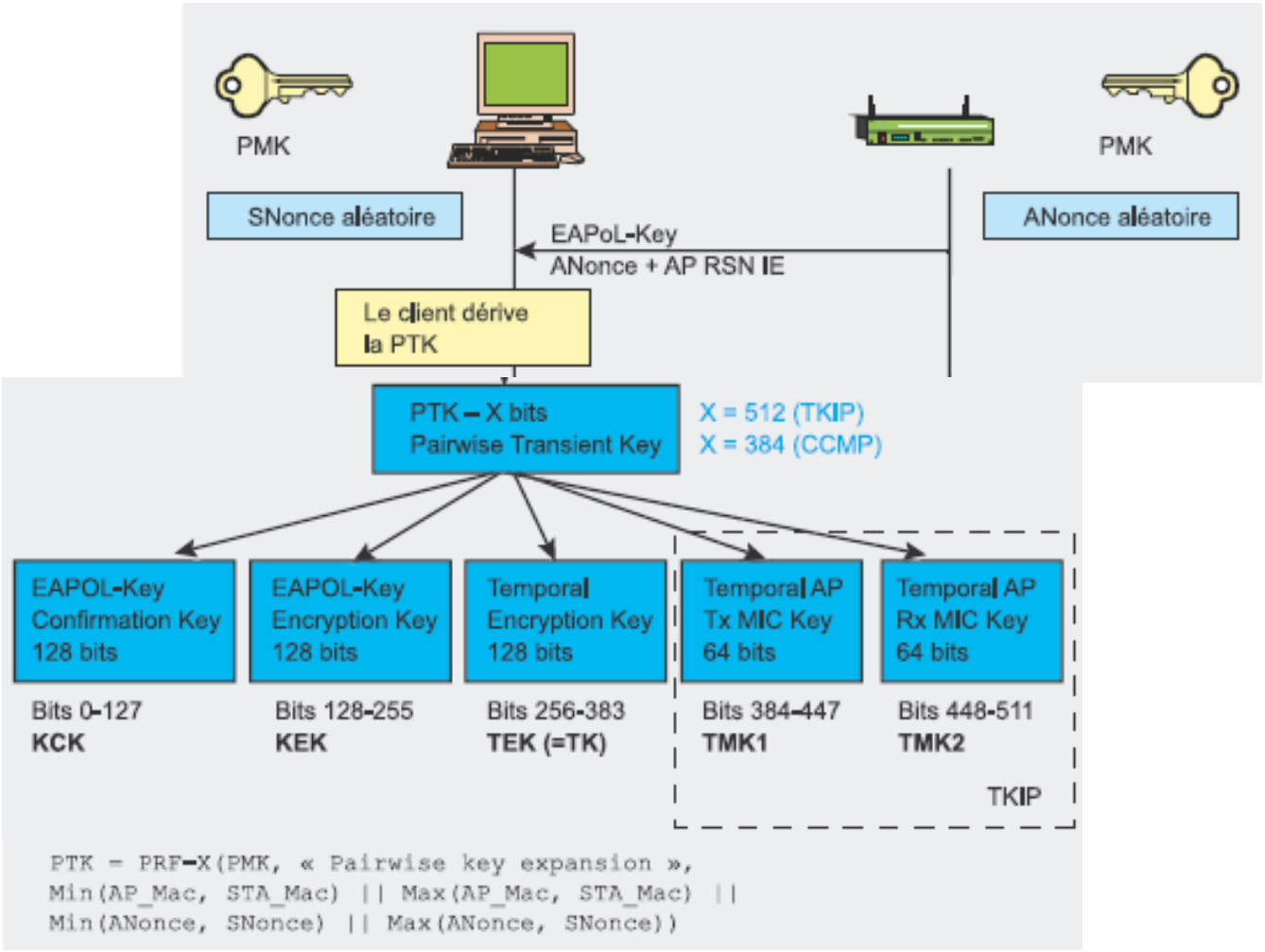
- TLS Handshake – Authentification du serveur par certificat
- TLS Record - Création d'un tunnel chiffré**.** Le protocole d'authentification du mot de passe circule dans le tunnel chiffré

La norme 802.11i: Phases opérationnelles



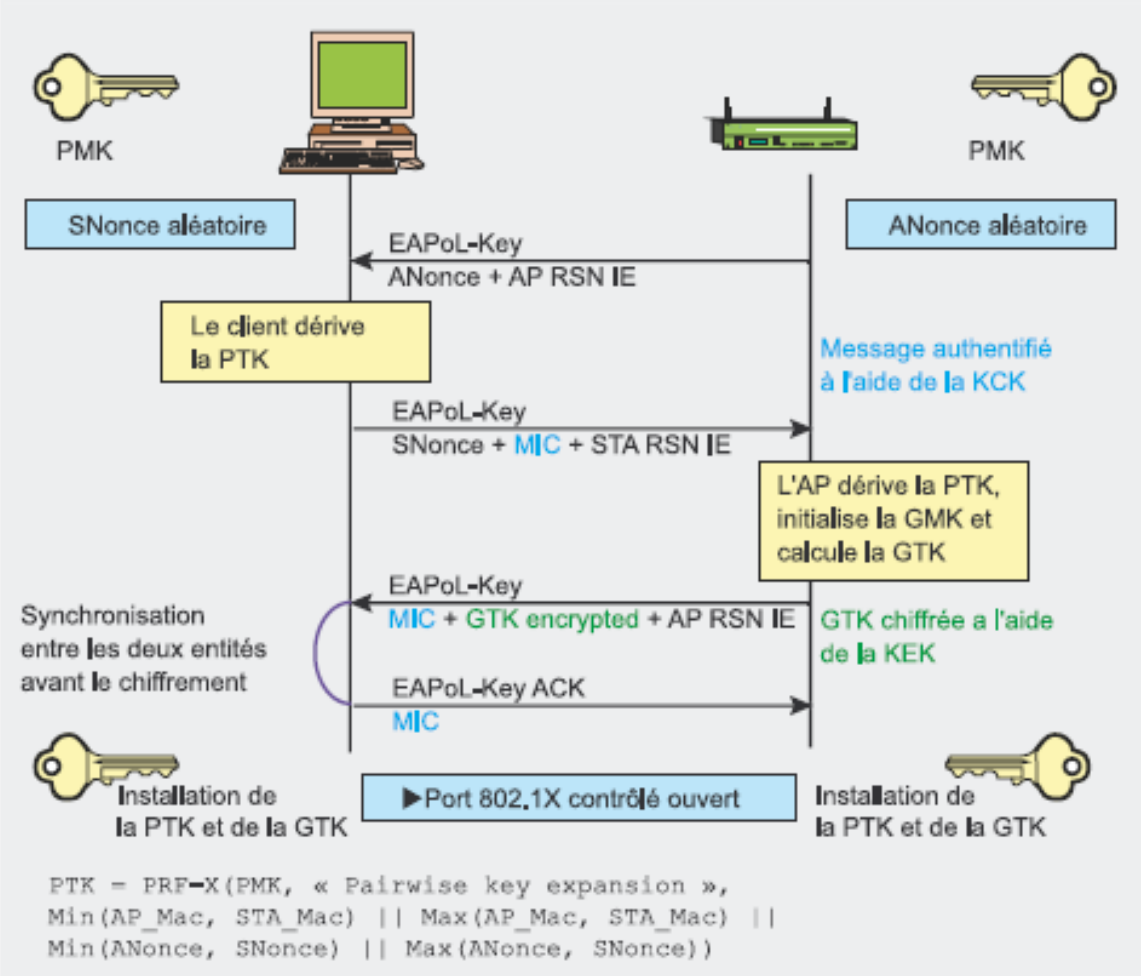
Phase 3: Hiérarchie et distribution des clés

4-Way Handshake: distribution des clés pairewise



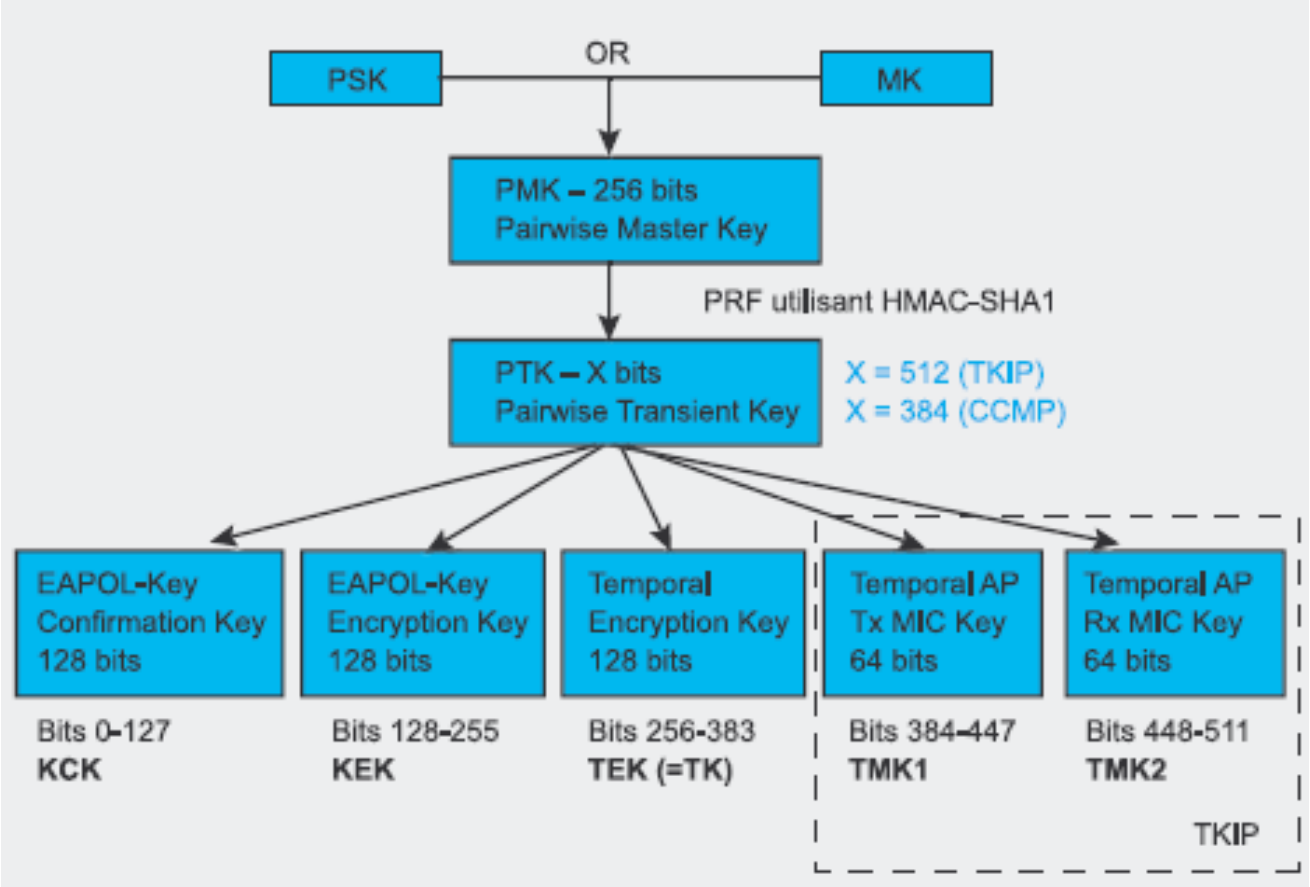
Phase 3: Hiérarchie et distribution des clés

4-Way Handshake: distribution des clés pairewise



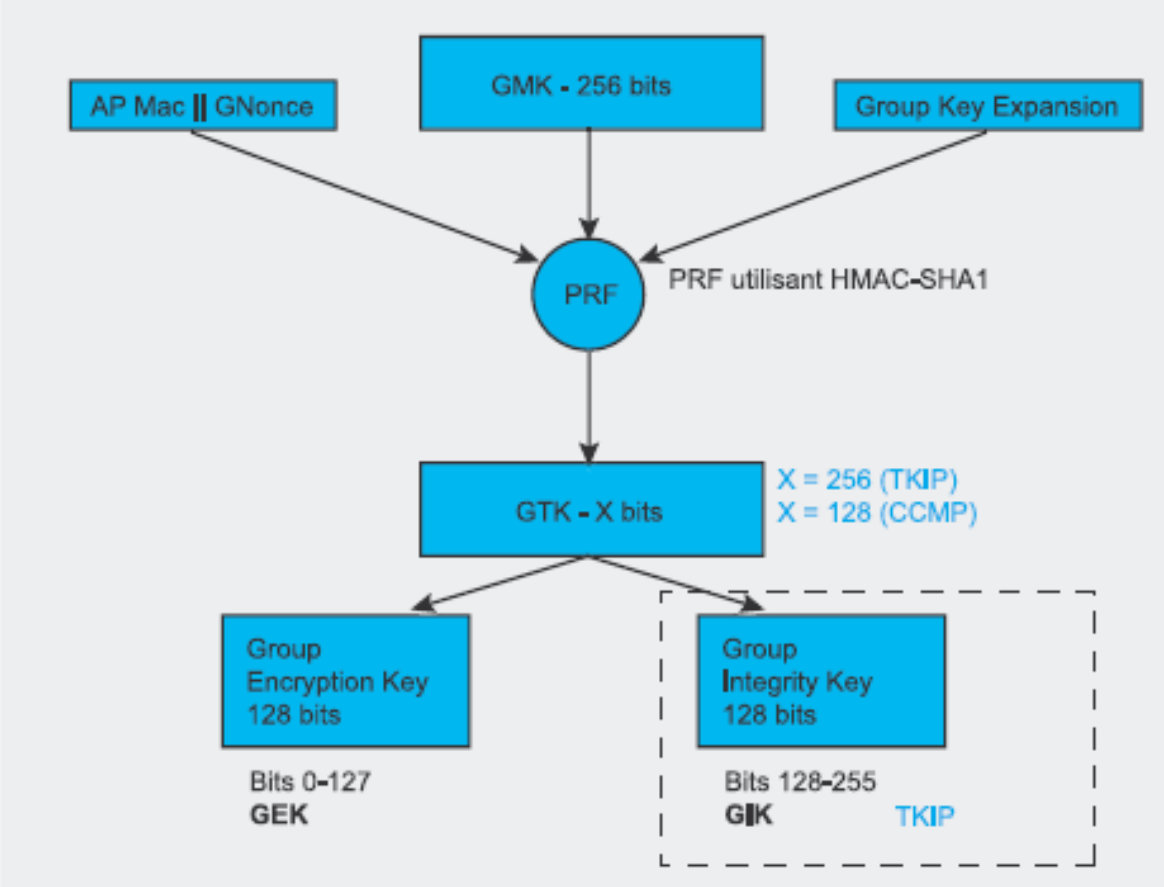
Phase 3: Hiérarchie et distribution des clés

Hiérarchie des clés pairewise

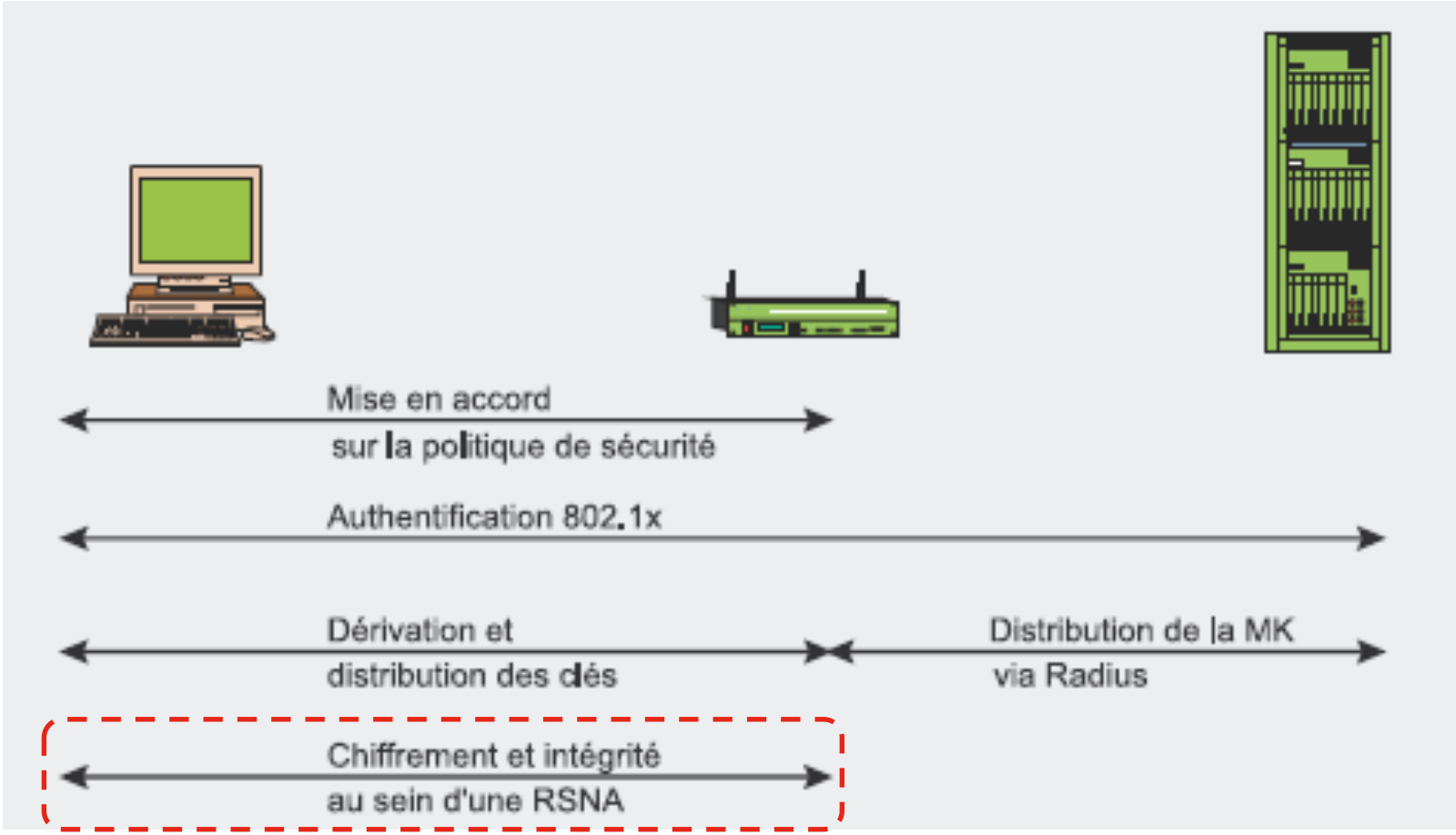


Phase 3: Hiérarchie et distribution des clés

Hiérarchie des clés de groupe



La norme 802.11i: Phases opérationnelles



Phase 4: Chiffrement et intégrité

-TKIP (Temporal Key Hash):

-IV : nouvelle méthode de sélection de valeur des IV, compteur anti-rejeu , augmentation de la taille (48)

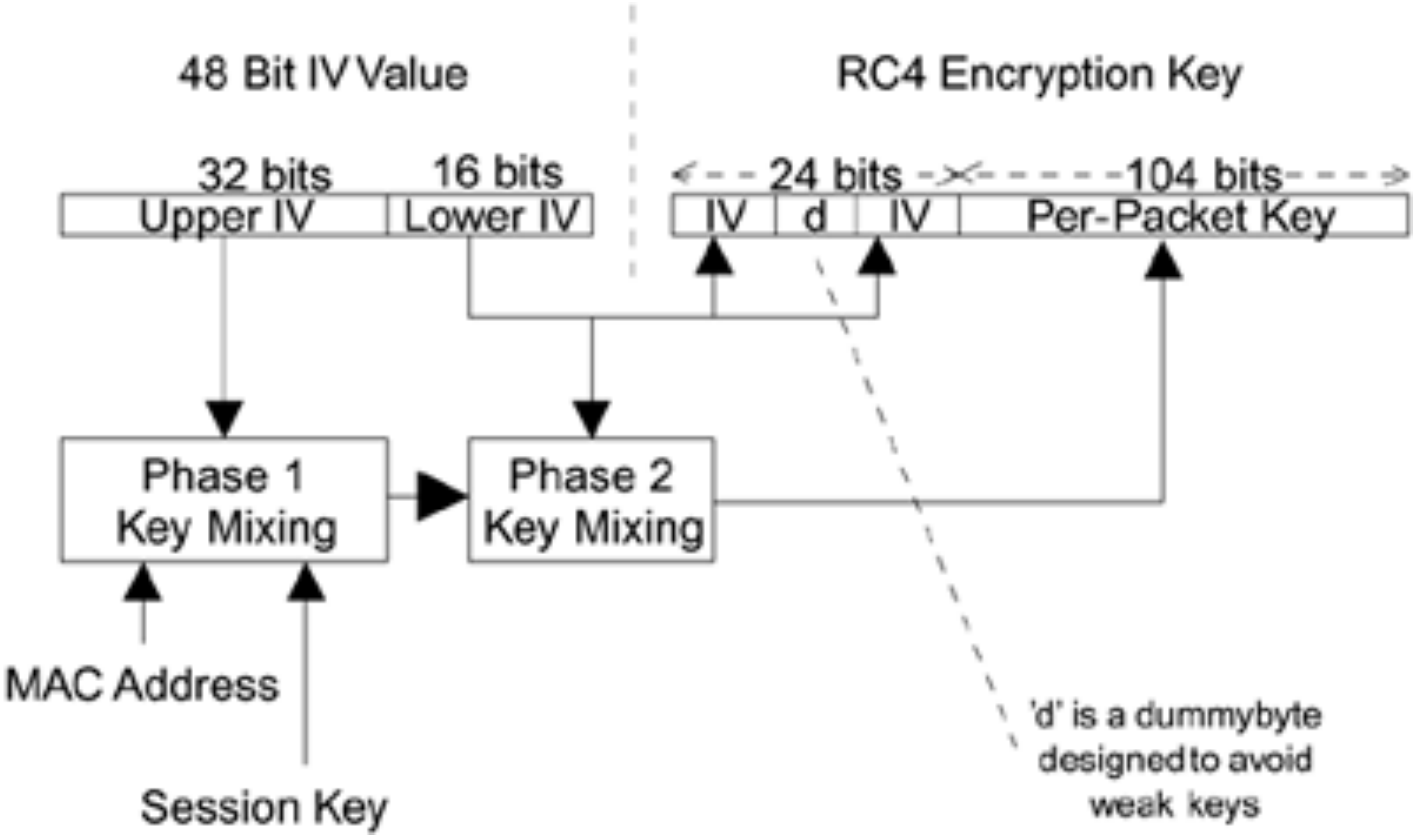
- Ne pas utiliser une clé unique (génération périodique des clés temporaires + key mixing à partir des IV et des clé temporaire)
- Intégrité : un nouveau MIC (Message Integrity Code) basé sur l'algorithme Michael

-CCMP (Counter-Mode/Cipher Block Chaining Message Authentication Code Protocol)

- Chiffrement par bloc (AES)
- Clé de 128 bits
- Blocs de 128 bits

Phase 4: Chiffrement et intégrité TKIP (WPA)

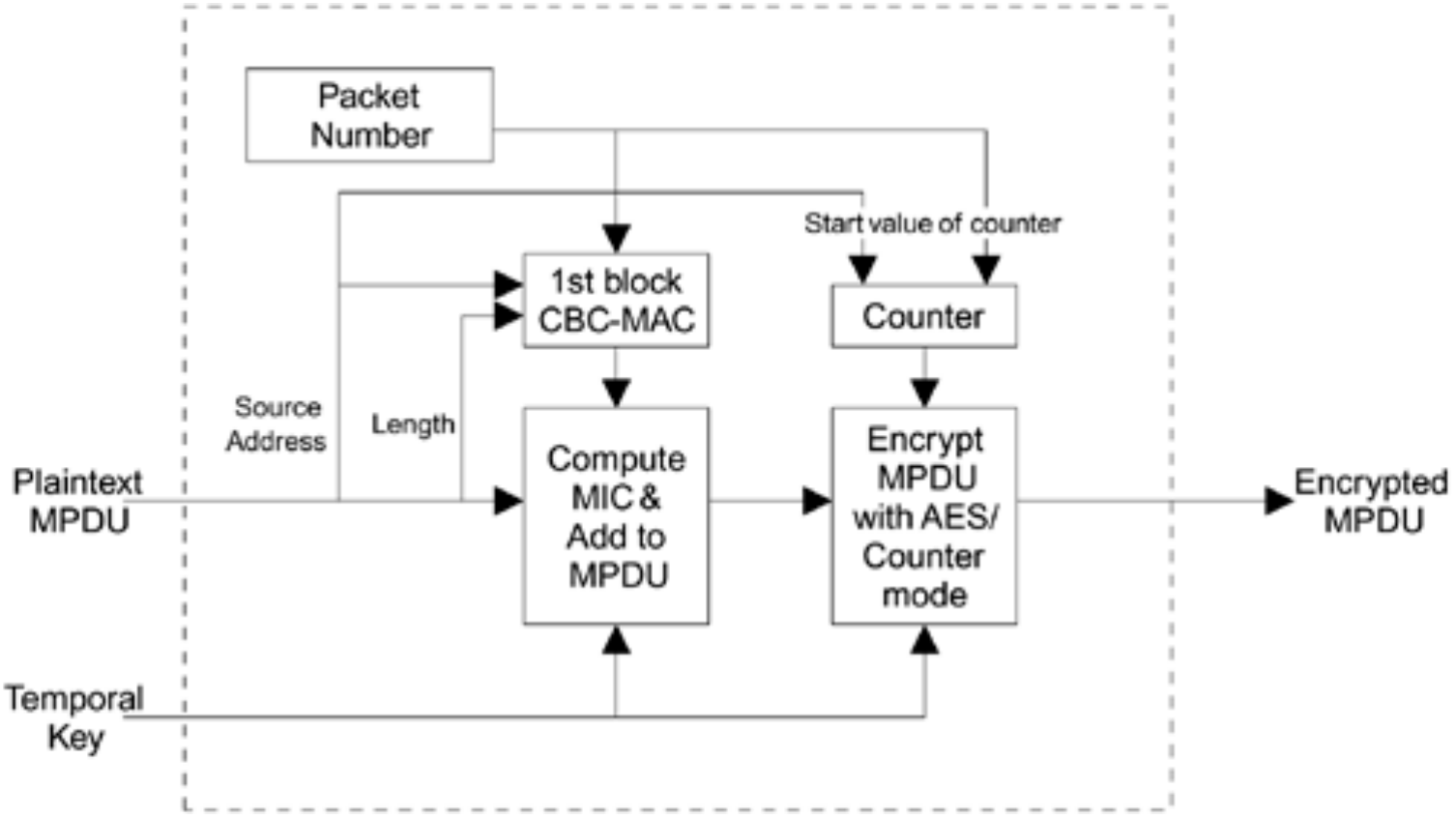
Basé sur RC4 (Algo de crypto symétrique par flot)



http://etutorials.org/Networking/802.11+security.+wi-fi+protected+access+and+802.11i/

Phase 4: Chiffrement et intégrité CCMP (WPA2)

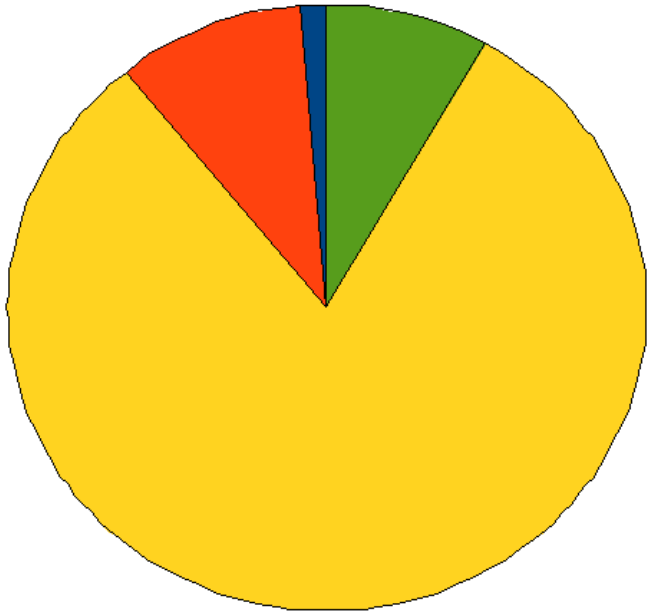
Basé sur AES (Algo de crypto symétrique par bloc)



http://etutorials.org/Networking/802.11+security.+wi-fi+protected+access+and+802.11i/

Attaques contre WPA / WPA2

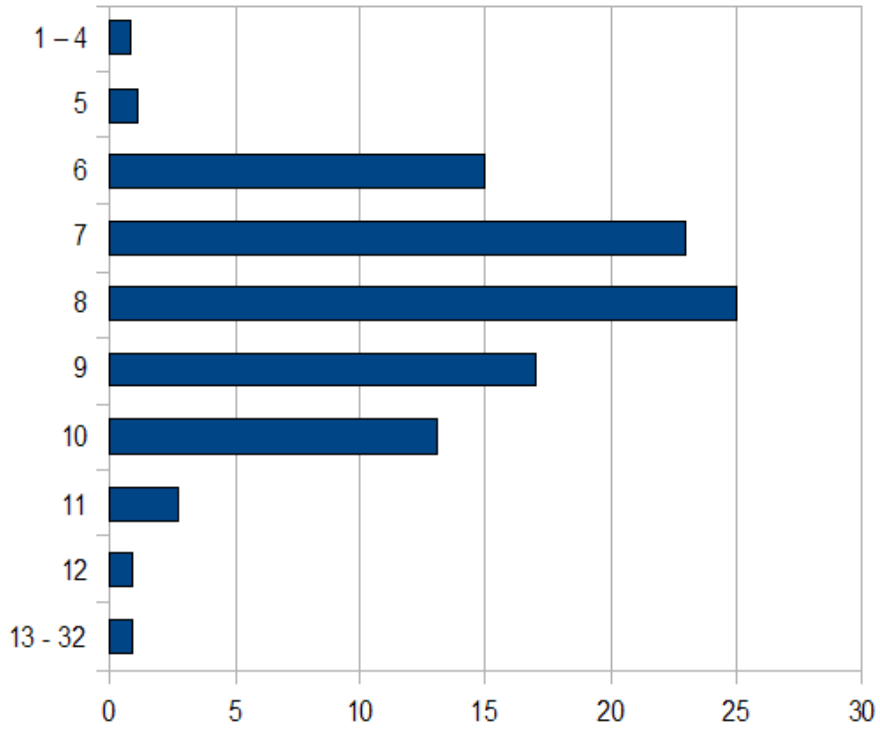
-L'attaque la plus courante et la plus utilisée est l'attaque par dictionnaire / ou brute force



Numéro uniquement	1.3 %
Lettres uniquement	9.6 %
Alphanumérique	81 %
Non alphanumérique	8.3 %

Composition des mots de passes (sur la base de 34 000 utilisateurs Myspace en 2006)

Attaques contre WPA / WPA2



1-4	0.82 %
5	1.1 %
6	15 %
7	23 %
8	25 %
9	17 %
10	13 %
11	2.7 %
12	0.93 %
13-32	0.93 %

Longueur des mots de passes (sur la base de 34 000 utilisateurs Myspace en 2006)

Attaques contre WPA / WPA2

❑ **Quelques attaques contre TKIP:**

- Erik Tews and Martin Beck. 2009. Practical attacks against WEP and WPA. In WiSec.

- Mathy Vanhoef and Frank Piessens. 2014. Advanced Wi-Fi attacks using commodity hardware. In ACSAC.

-« Décrpytage » de petits paquets

Attaques contre WPA / WPA2

❑ **Key reinstallation attacks (KRACKs): Novembre 2017**

-Mathy Vanhoef and Frank Piessens. 2017. Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2. In ACM CCS.

- L'idée principale est de forcer la réinitialisation des compteurs IV anti-rejeu grâce à la réinstallation d'une clé déjà en cours d'utilisation

❑ **Problème de standard ou d'implémentation ??? !!!**

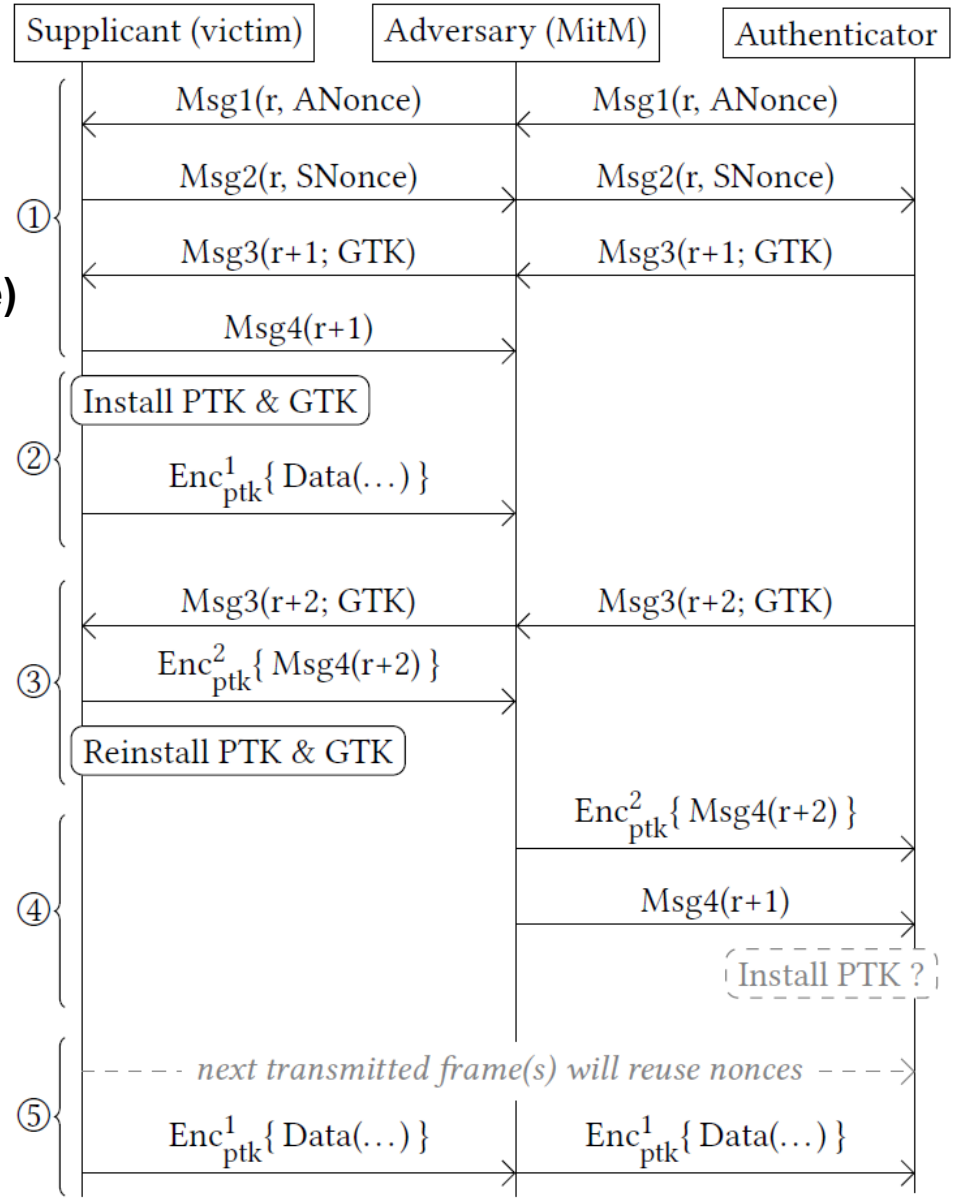
❑ **Hypothèses de l'attaque:**

- L'implémentation doit accepter la retransmission des messages 3 conformément à la norme (pas le cas des implémentations Windows et iOS)

- La possibilité de mettre en place une attaque Man in the Middle avec un Rogue AP ayant la même @ MAC (clonage de l'AP sur un autre canal)

Attaques contre WPA / WPA2

Principe de l'attaque (version basique)



Attaques contre WPA / WPA2

- **Key reinstallation attacks (KRACKs): conséquences**
  - TKIP: trouver les suites chiffrantes et les MIC → «décryptage » de tous les paquets + injection et rejeu,
  - CCMP: «décryptage » de quelques paquets + rejeu
- **Key reinstallation attacks (KRACKs): contre-mesures**
  - Ne pas autoriser la retransmission du message 3
  - Ne pas réinitialiser les compteurs si la même clé est déjà installée
  - N'installer les clés qu'une seule fois

WPA3

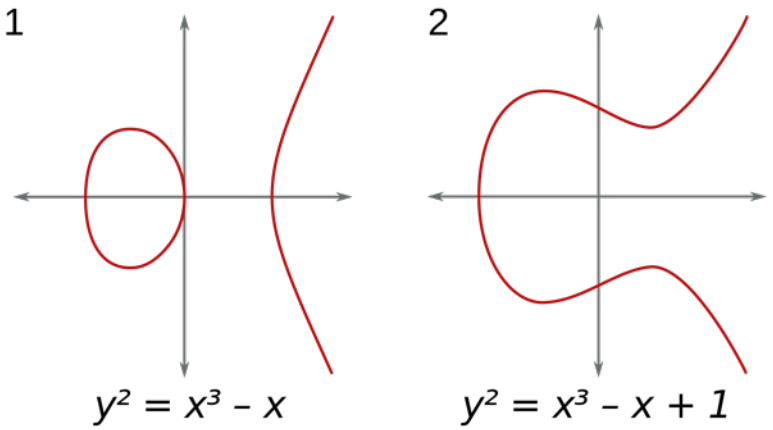
- Hadshake en 4 phases, remplacé par un échange de clé « Dragonfly Key Exchange »
- Dragonfly utilise la cryptographie basée sur le problème du logarithme discret pour l'authentification et la génération des clés (RFC 7664)
- Finite Field Cryptography (FFC), Elliptic Curve Cryptography (ECC), etc.
- Dans ce qui suit, nous présentons la variante de la cryptographie sur courbes elliptiques (ECC)

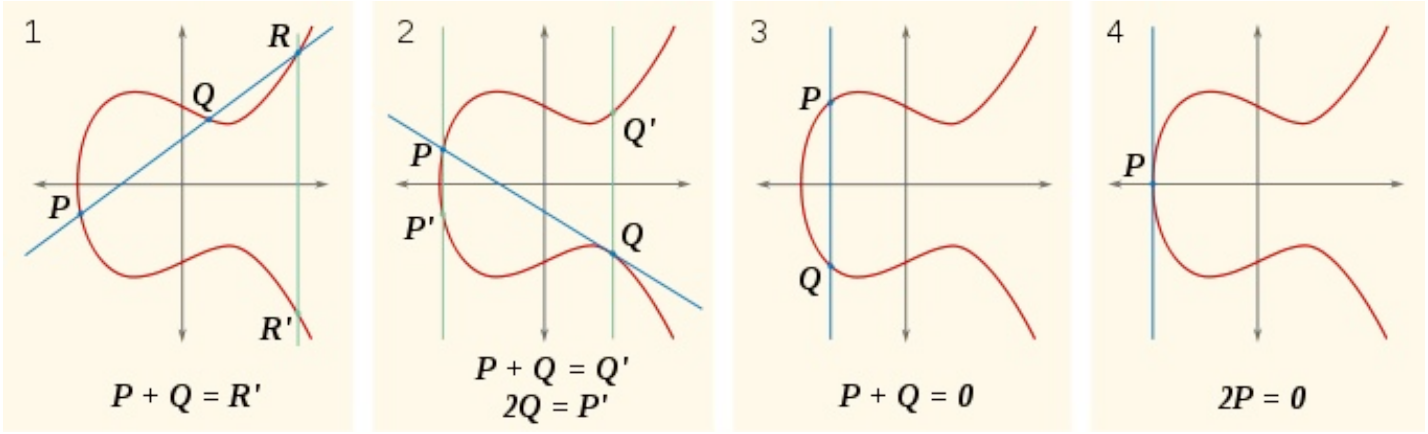
Rappel: ECC

Rappel: ECC sur un corps fini Z/qZ: points satisfaisant l'équation

$$y^2 \equiv x^3 + a \,.\, x + b$$

Source des images: Wikipédia





Rappel: ECC

Rappel: ECC sur un corps fini Z/qZ: points satisfaisant l'équation

$$y^2 \equiv x^3 + a \cdot x + b$$

	Alice	Bob
Étape 1 :	Alice et Bob choisissent ensemble une courbe elliptique $E(a, b, \mathbb{K})$ et un point P sur la courbe. Cet échange n'a pas besoin d'être sécurisé.	
Étape 2 :	Alice choisit secrètement k_A et envoie $k_A P$ à Bob. Cet échange n'a pas besoin d'être sécurisé.	Bob choisit secrètement k_B et envoie $k_B P$ à Alice. Cet échange n'a pas besoin d'être sécurisé.
Étape 3 :	Alice calcule $k_A(k_B P) = (k_A k_B)P$.	Bob calcule $k_B(k_A P) = (k_A k_B)P$.

http://www.bibmath.net/crypto/index.php?action=affiche&quoi=complements/cryptoelliptique

Rappel: ECC

Rappel: ECC sur un corps fini Z/qZ: points satisfaisant l'équation

$$y^2 \equiv x^3 + a \,.\, x + b$$

Caractéristique très importante :

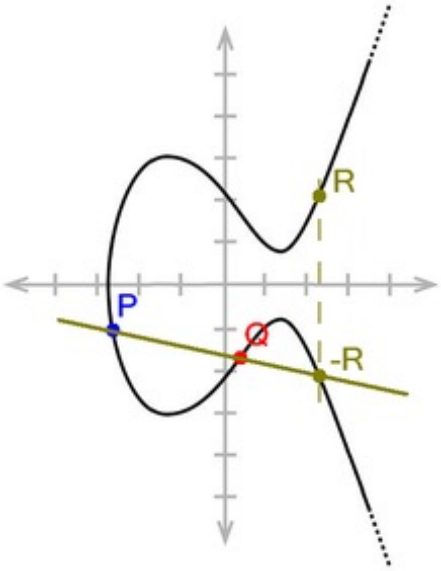
- En ayant un point P et un scalaire k , il est « facile » de calculer Q= k.P

- En ayant deux points P et Q , il est « impossible » « **à ce jour**» de calculer dans **dans un temps raisonnable** k tel que Q= k.P

Etape 1: Dérivation du Password Element (PWE)

Rappel: ECC sur un corps fini Z/qZ: points satisfaisant l'équa

$$y^2 \equiv x^3 + a \,.\, x + b$$



- Calculer un hach basé sur les adresses mac des participants + le mot de passe partagé + le compteur.
- Ce hach est utilisé comme « seed» pour une fonction de dérivation de clé KDF.
- Le résultat est utilisée comme coordonnée x pour l'équation de la courbe. Vérifier s'il s'agit d'un résidu quadratique. Si ce n'est pas le cas, augmenter le compteur de 1 et réessayer

Etape 1: Dérivation du Password Element (RFC 7664)

```
found = 0
        counter = 1
        n = len(p) + 64
        do {
          base = H(max(Alice,Bob) | min(Alice,Bob) | password | counter)
          temp = KDF-n(base, "Dragonfly Hunting And Pecking")
          seed = (temp mod (q - 1)) + 1
          if ( (seed^3 + a*seed + b) is a quadratic residue mod q)
              x = seed
              save = base
              found = 1
          fi
          counter = counter + 1
        } while ((found == 0) || (counter <= k))

        y = sqrt(x^3 + ax + b)
        if ( lsb(y) == lsb(save) )
              PWE = (x,y)
        else
              PWE = (x,p-y)
        fi
```

Etape 2: The Commit Exchange

q: un nombre premier qui représente l'ordre du générateur G (la taille du sous-groupe cryptographique)

Chaque pair choisit deux nombres aléatoires, private (r) et mask (m)

$1 < r < q$
$1 < m < q$

scalar = (r + m) modulo q
Element = - (m * PWE)

Les pairs échangent leurs "scalar" (s) et "Element" (E), le secret partagé est:

K = r * (peer-scalar * PWE + peer-Element)

kck | mk = KDF-n(F(K), "Dragonfly Key Derivation")

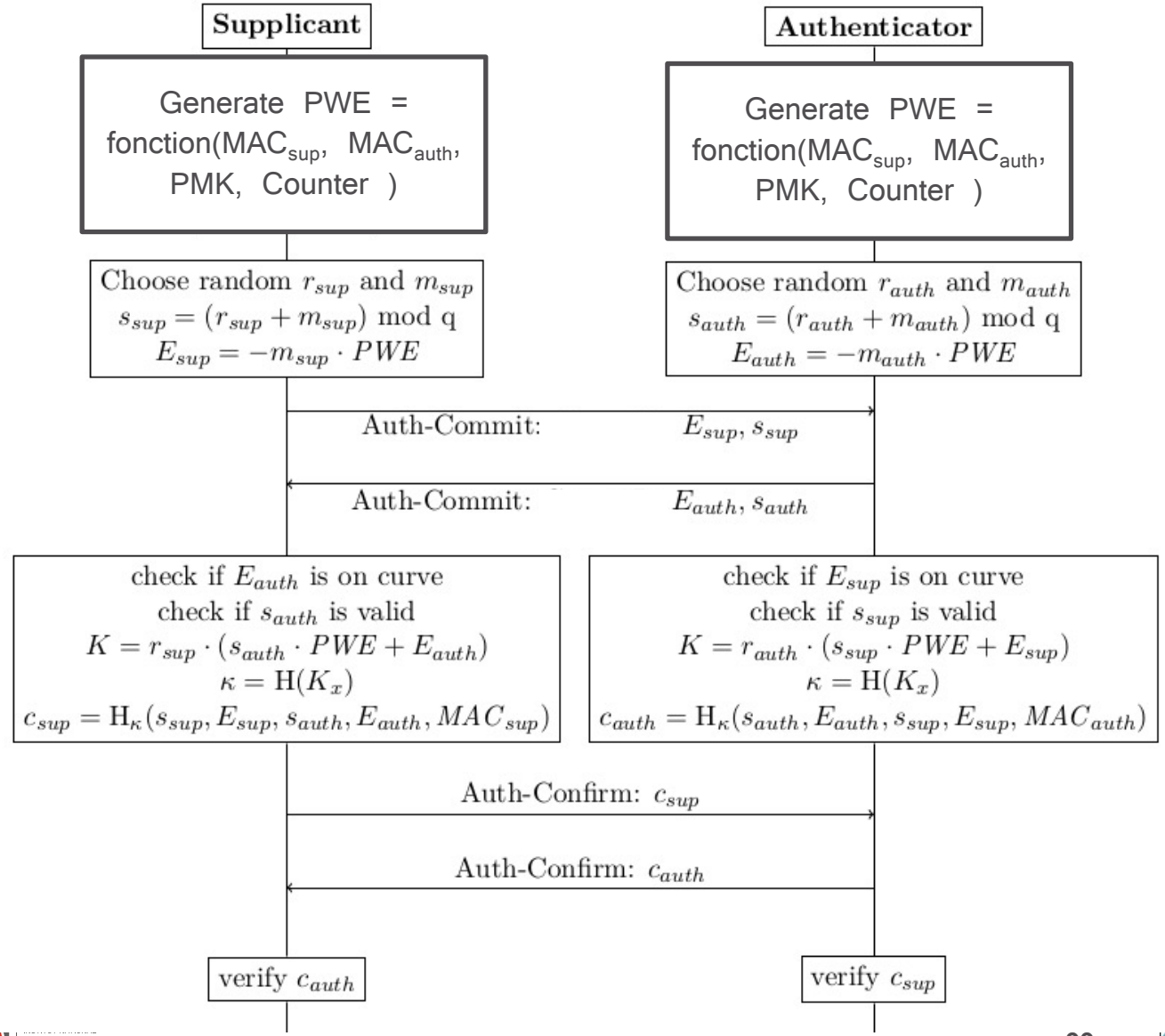
Etape 3: The Confirm Exchange

Chaque pair calcule un hash de confirmation, confirm (c), et l'envoie à l'autre pair.

confirm = H(kck | scalar | peer-scalar | Element | Peer-Element | <sender-id>)

Les deux parties peuvent confirmer qu'elles possèdent le même hash et qu'elles ont donc le même secret partagé.

Echanges WPA3



WPA3 Vs WPA2

- Dans WPA2, un attaquant peut désauthentifier une STA, capturer les échanges handshake et lancer une attaque par dictionnaire **hors ligne**.
- Avec Dragonfly, cela n'est pas faisable, car "scalar" et "element" ne révèlent rien "private" et "mask"
- Sans ces valeurs, un attaquant ne peut pas vérifier si un mot de passe est correct ou pas
- L'attaquant doit participer à un échange avec le pair pour deviner le mot de passe

Respect de la vie privée

- **Adresses MAC unique:**

  - 48 bits dont 24 identifie le **constructeur** (champs OUI)

- **SSID régulièrement diffusés par les stations:**

  - **SSIDS nominatifs** (nom d'organisation, nom d'événements, Nom du propriétaire, adresse postale, etc.)

  - **Possibilité de géo localisation (**WiGLe , Openbmap, etc.)

  - **Liens sociaux (**taux de partage des réseaux personnels, métrique de similarité, etc. **)**

- **Traçage des Individus:**

  - **Traçage radio** grâce au RSSI

  - **Possibilité de traçage WiFi** (plateforme de capteurs ou de PA)

Respect de la vie privée

- **Différents champs d'applications:**
  - Centres commerciaux, collectivités et transport en commun, événements de masse, publicité ciblée, etc.
  - Optimisation de l'allocation des ressources humaines, amélioration du service, etc.
- **Le principal problème est l'unicité des adresses MAC**
- **Anonymisation des adresses MAC**
  - Est-elle une vraie solution ?
- **Autre directions: cacher les réseaux WiFi (ne pas diffuser le SSID) ?**

Quelques références

- Sécurité Wi-Fi – WEP, WPA et WPA2 Guillaume Lehembre, 2006
- Alan Holt and Chi-Yu Huang 802.11 Wireless Networks Security and Analysis, Springer, 2010
- Aircrack-ng : https ://www.aircrack-ng.org
- Wifi Professionnel - La Norme 802.11, Le Déploiement, La Sécurité Aurélien Géron, Broché , 2009
- Nikolai Tschacher, WPA3 Dragonfly Handshake– SAE Handshake, 2019
- John Franco, Elliptic Curve Public Key Cryptography, 2019

Merci ☺